

CURSO *ONLINE* DE CIBERSEGURIDAD__

Unidad 5. Análisis forense



Contenidos

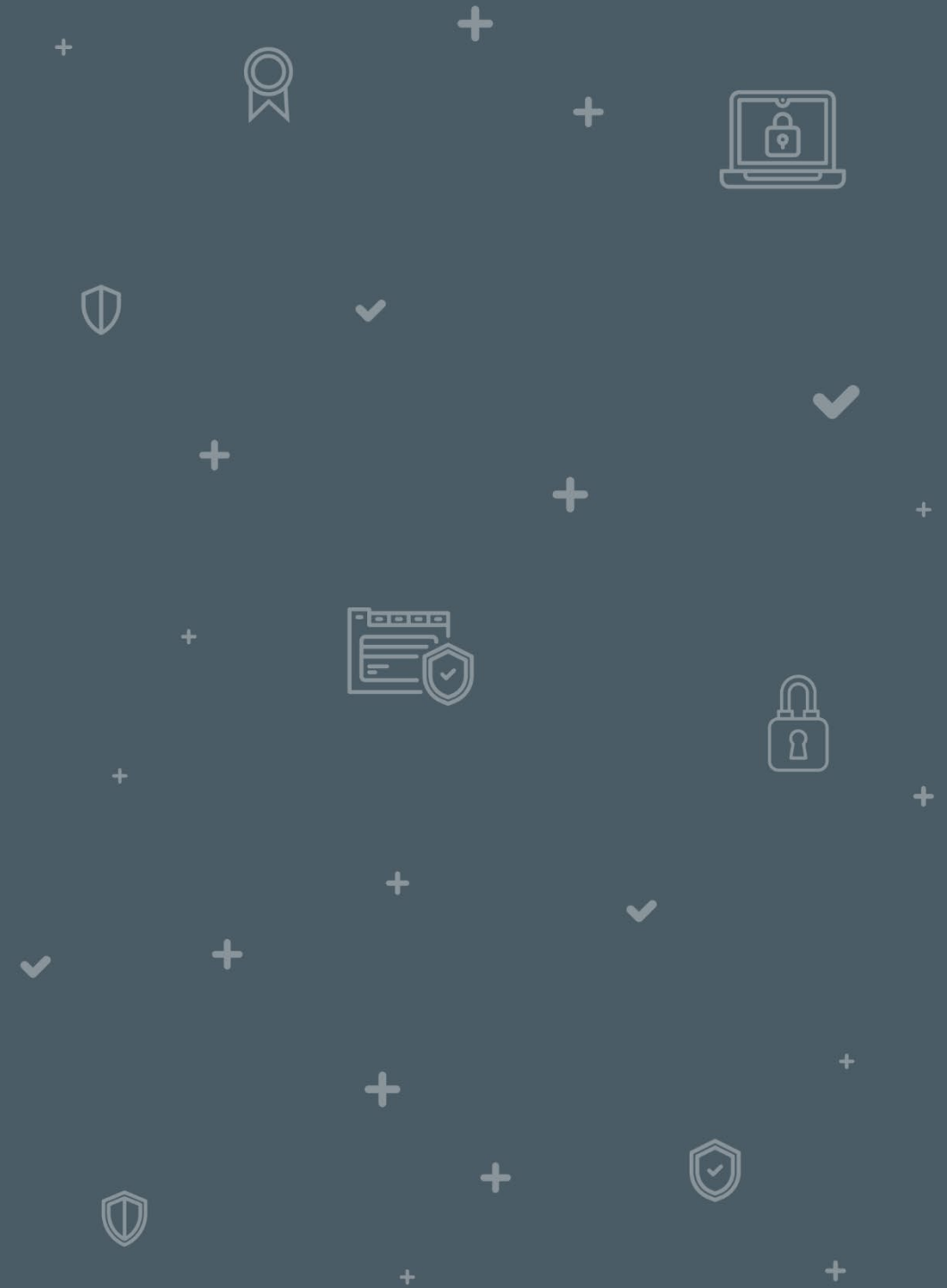
1	INTRODUCCIÓN	4
2	FASES DEL ANÁLISIS FORENSE	22
3	ANÁLISIS FORENSE DE <i>MALWARE</i>	113
4	ANÁLISIS ESPECIALES	137
5	METODOLOGÍA FORENSE	161

OBJETIVOS

- Describir los conceptos de «cadena de custodia» y «firmado de evidencias», así como el procedimiento de cada uno de ellos que tiene lugar durante una investigación forense.
- Comprender el procedimiento de la investigación forense digital y cada una de sus fases: identificación, adquisición de evidencias, análisis de evidencias e informe final.
- Conocer los aspectos principales del análisis forense y profundizar en el análisis de *malware*.
- Analizar las principales herramientas forenses de *hardware* y *software* que existen para realizar cualquier actividad en el ámbito del análisis forense, así como los diferentes tipos de dispositivos no comunes.
- Conocer las principales normativas aplicables a la investigación forense y las buenas prácticas que se podrían llevar a cabo al realizar algunos procedimientos.

INTRODUCCIÓN

1



1 INTRODUCCIÓN

Contexto

En la actualidad, cada vez son más las amenazas a las que se enfrentan las personas y las organizaciones, debido, principalmente, a la gran expansión de Internet durante los últimos años, que ha conllevado el aumento de las tecnologías móviles, la utilización de tecnologías IT dentro de los procesos organizativos y el auge de la tecnología IoT.

De manera proporcional al aumento del uso de tecnologías de la información, también ha surgido un número mayor de amenazas de ciberseguridad. A medida que los atacantes han descubierto maneras más novedosas de explotar estas nuevas tecnologías, han ido surgiendo nuevas vulnerabilidades que, a su vez, han generado nuevos incidentes de seguridad.



1 INTRODUCCIÓN

Incidente de seguridad

En el ámbito de la seguridad informática, a la hora de hablar sobre el análisis forense, primero vamos a definir qué son los incidentes de seguridad, dado que este tipo de análisis está estrechamente ligado a este concepto.

Un **incidente de seguridad** hace referencia a una violación de la política de seguridad de la información de una organización, esta es, un conjunto de medidas destinadas a proteger y preservar la confidencialidad, la integridad y la disponibilidad de la información. Un ejemplo de incidente de seguridad sería el acceso a la infraestructura de una organización por un individuo que no debería tener permisos de acceso.



1 INTRODUCCIÓN

Tipos de incidentes de seguridad

Existen muchos tipos de incidentes de seguridad, pero lo más comunes son:

- **Un acceso indebido o no autorizado:** una persona no autorizada podría obtener acceso a los sistemas de la organización o a una zona restringida a su puesto.
- **Robo de información:** siguiendo el ejemplo anterior, si la persona finalmente ha accedido a los sistemas, podría tener acceso a información confidencial y sensible y, como consecuencia, podría llegar a sustraerla.
- **Alteración de datos en los sistemas:** consiste en modificar la información o los datos almacenados en los sistemas a los que el usuario ha obtenido acceso.
- **Denegación o degradación del servicio:** a través de la petición masiva de solicitudes o conexiones de forma simultánea, se pretende conseguir inhabilitar el uso de un sistema, aplicación o máquina con el objetivo de bloquear el servicio que está dando.

INTRODUCCIÓN

Tipos de incidentes de seguridad

¿Sabías qué?

Para arremeter contra unos *streamers*, unos atacantes realizaron un ataque DDoS a una operadora de telecomunicaciones. [\[1\]](#)

- **Malware:** es un código malicioso cuyo objetivo es infectar los dispositivos.

¿Sabías qué?

El mayor ciberataque de *ransomware* hasta el momento ha sido a una empresa tecnológica a la que se le ha exigido 50 millones. [\[2\]](#)

1 INTRODUCCIÓN

Tratamiento de incidentes de seguridad

Como hemos visto en la unidad anterior, para poder enfrentarnos a un incidente de seguridad será necesario tomar las medidas necesarias y adecuadas para evitar que la incidencia se extienda por todos los sistemas de la organización, minimizar los daños derivados de este y mitigar el impacto del incidente. Además, cabe destacar que estas funciones de contención del incidente deben realizarse con la mayor celeridad posible.

Una vez contenido el incidente, y en función de su gravedad, se puede considerar conveniente realizar una investigación forense para determinar cuál ha sido el origen de la incidencia. El enfoque que se adopte para realizar la investigación forense dependerá de varios factores:

- El tipo de incidente.
- La capacidad del equipo para hacer frente al incidente.
- Los recursos tanto materiales como humanos de los que se disponga.
- Los procedimientos definidos por la organización en caso de que se produzca un incidente de seguridad.

1 INTRODUCCIÓN

¿Qué es la informática forense?

Ahora que hemos comprendido el concepto de incidente de seguridad, vamos a definir qué es la informática forense.

La **informática forense** es la aplicación de técnicas de investigación para la recogida de evidencias en diferentes dispositivos informáticos para, a continuación, ser analizadas en busca de pruebas que puedan aclarar lo que ha ocurrido en el equipo y puedan incluso ser presentadas en un juicio. Cabe destacar que, si bien es habitual realizar un análisis forense sobre un incidente de seguridad, el análisis forense no versa únicamente sobre este tipo de sucesos, sino que también se puede emplear para analizar hechos delictivos realizados por medios digitales, como el acoso, la suplantación de identidad, las imágenes de abuso sexual infantil, etc. Además, sirve de apoyo en investigaciones policiales donde se crea que la información digital puede aclarar ciertos aspectos de la investigación. Por ejemplo, disponer del dispositivo móvil de personas desaparecidas para determinar dónde pueden estar o qué hicieron o dónde se encontraban en los momentos anteriores a la desaparición.

1 INTRODUCCIÓN

¿Qué es la informática forense?

Estos dispositivos informáticos pueden haberse visto implicados en el incidente de tres formas diferentes:

- El dispositivo como herramienta, es decir, desde donde se realiza el ataque, por ejemplo, desde un dispositivo que controla una *botnet* o un equipo desde el que se envían mensajes amenazantes, etc.
- El dispositivo como objetivo: es el propio dispositivo el que ha sufrido el incidente de seguridad, como en el caso de ser atacado por un virus.
- El dispositivo como medio: hace referencia al uso del dispositivo para realizar el ataque, por ejemplo, utilizando el ordenador con un *proxy*.

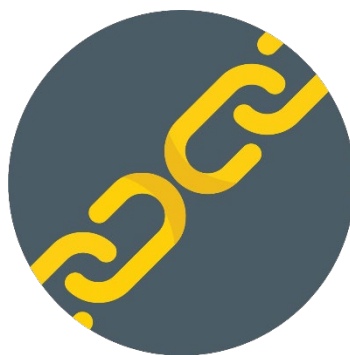


1 INTRODUCCIÓN

¿Qué es la informática forense?

Esta tarea es llevada a cabo por un **analista forense**, cuyo cometido principal es hacer una investigación, analizando de forma sistemática las pruebas que se hayan adquirido. Asimismo, debe garantizar la integridad de las evidencias, de una forma que se conoce como **cadena de custodia**.

Entre sus funciones, también destaca realizar un informe que incluya la documentación que acredite lo sucedido en los equipos, presentando una narrativa veraz de lo ocurrido para que se puedan tomar las medidas oportunas al respecto.



1 INTRODUCCIÓN

Análisis forense

Un **análisis forense** digital es un proceso definido y procedimentado mediante el cual se busca determinar los hechos acontecidos durante el suceso de un incidente de seguridad informático.

El análisis forense busca ofrecer una información detallada de los siguientes puntos clave:

- **¿Qué ha ocurrido?:** es la primera pregunta clave para comenzar el proceso del análisis forense y su respuesta permitirá definir unos primeros pasos o procedimientos a seguir para realizar el análisis y las recomendaciones que se deben llevar a cabo para la contención y recuperación de los equipos afectados de la mejor manera posible. Vamos a poner el ejemplo de que ha ocurrido un ataque de filtración de datos de una organización.
- **¿Dónde ha ocurrido?:** la información de la localización del incidente, es decir, en qué parte de la red se ha detectado, unida a la información acerca del equipo y la información que nos pueda proporcionar su red, serán de gran ayuda a la hora de acotar el análisis. Siguiendo con el ejemplo anterior, vamos a suponer que ha tenido lugar en la red corporativa de la organización.

1 INTRODUCCIÓN

Análisis forense

- **¿Cómo ha ocurrido?:** determinar la manera en la que se ha producido el incidente implicará localizar la causa principal del mismo y comprobar si se ha explotado alguna vulnerabilidad de los sistemas de la organización. Para responder a esta pregunta se deberán utilizar tanto los recursos técnicos como las personas que trabajan en la organización. En nuestro caso, se ha descubierto que ha sido mediante un ataque de *phishing* a través de un correo malicioso enviado a los empleados.
- **¿Por qué ha ocurrido?:** esta pregunta es la más difícil de responder, ya que un incidente de seguridad se puede producir por motivos técnicos, por fallos humanos o por intenciones maliciosas y ataques de un tercero. En este último tipo de incidentes será necesario tener claro el perfil de la organización, así como sus posibles competidores, su reputación, el nivel de concienciación de seguridad de los empleados, etc. Por otro lado, los motivos podrían ser robar la información de los clientes de la organización para poder venderla a terceros o utilizar los datos para llevar a cabo más ataques contra la empresa.

1 INTRODUCCIÓN

Análisis forense

- **¿Cuándo ha ocurrido?:** además, se deberá establecer una línea temporal que permita identificar el instante en el que se produjo el incidente y qué sucedió después de que ocurriera. Esto será un requisito fundamental en la gestión del proceso.

A la hora de realizar un análisis forense se debe tener en cuenta que siempre será un proceso altamente técnico y mecánico para el que no existe ninguna metodología «ideal» para su realización.

Un analista forense dispondrá de numerosas utilidades que le serán de gran ayuda a la hora de extraer, documentar, analizar y procesar las evidencias, pero es importante saber que no existe una herramienta que automatice todo el trabajo necesario durante este procedimiento.



1 INTRODUCCIÓN

Análisis forense

Una **evidencia** es todo aquel elemento o información que permite establecer la relación entre otros dos o más elementos encontrados en la escena. En el ámbito digital, este término hace referencia a todo aquel elemento que pueda almacenar información, ya sea de forma física o lógica, y que permita ayudar a esclarecer un caso o incidente sufrido. Una evidencia debe cumplir una serie de reglas, siendo estas: de **pertinencia**, es decir, debe estar relacionada de forma directa con el caso; de **validez**, las evidencias deben ser adecuadas, suficientes y confiables, y de **competencia**, es decir, debe encontrarse dentro de parámetros físico, psíquicos, legales, científicos, etc.

Por otro lado, una **prueba** se refiere a aquellos elementos o procesos que se utilizan con el fin de demostrar si un hecho es veraz o no.

1 INTRODUCCIÓN

Análisis forense

A su vez, es muy importante tener en cuenta que todo proceso forense debe garantizar la **veracidad de las evidencias**, esto es, que no hayan sufrido ninguna alteración o hayan sido manipuladas de ninguna forma, permitiendo que, en caso de duda, se puedan repetir las pruebas realizadas con el objetivo de obtener el mismo resultado.

¿Sabías qué?

Estos son algunos de los casos de análisis forense más peculiares. [\[3\]](#)

1 INTRODUCCIÓN

Perspectivas del análisis forense

Como se ha mencionado anteriormente, cada vez son más los dispositivos informáticos que utilizamos en nuestro día a día y que guardan toda la información de las actividades que realizamos con ellos. Estos dispositivos podrían presentar información útil a la hora de determinar las causas de un incidente de seguridad o de un delito cibernético, y es ahí donde entra en juego el análisis forense.

- Desde la perspectiva **organizativa**, el análisis forense es un proceso que, una vez ocurre un incidente de seguridad, tiene como objetivo principal conocer cuáles fueron las causas del mismo, quiénes fueron los responsables y poder determinar qué posibles acciones se deben aplicar para que no vuelva a ocurrir este tipo de incidentes. Hay que tener en cuenta que este análisis se debe realizar con garantías y siguiendo una metodología clara y estricta, por si se da el caso de que la investigación pueda derivar en un juicio.

1 INTRODUCCIÓN

Perspectivas del análisis forense

- Desde un punto de vista **judicial**, el análisis forense se lleva a cabo para determinar los hechos ocurridos en un procedimiento judicial. Es importante fijar el alcance de la investigación y, sobre todo, realizar un seguimiento en el análisis judicial, ya que si se investigan otros planteamientos que no estaban definidos en el alcance, podría llegar a anularse la investigación realizada.



1 INTRODUCCIÓN

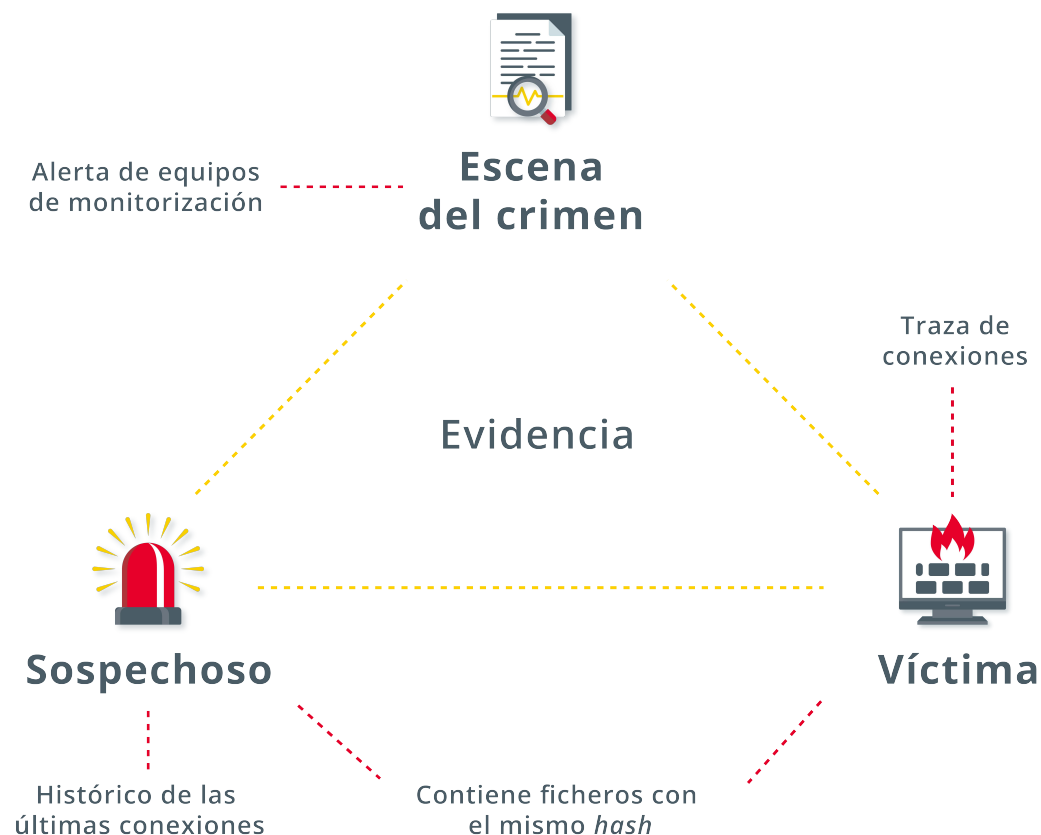
Principio de intercambio de Locard

A la hora de realizar cualquier análisis forense se debe tener en cuenta el **principio de intercambio de Locard**, un criminalista francés del siglo XX. Una de sus frases célebres es que «*siempre que dos objetos entren en contacto, transfieren parte del material que incorporan al otro objeto*». Esto significa que, en cualquier tipo de delito, siempre se deja un rastro. El principio de intercambio de Locard establece que, cuando un criminal actúa en lo que luego será la escena del crimen, o entra en contacto con la víctima, la víctima siempre tiene una traza del delincuente, y el delincuente se lleva algo a cambio. Mediante un análisis forense se pueden obtener evidencias, como hemos visto, del tipo de ataque, a qué sistemas ha afectado, cuál ha podido ser su origen, etc. A la hora de realizar el análisis forense, también se cumple este principio de intercambio y, precisamente, por esta razón, se debe actuar con especial cuidado a la hora de recopilar evidencias para que el sistema a analizar se vea afectado en la menor medida posible, al igual que las evidencias adquiridas.

1 INTRODUCCIÓN

Principio de intercambio de Locard

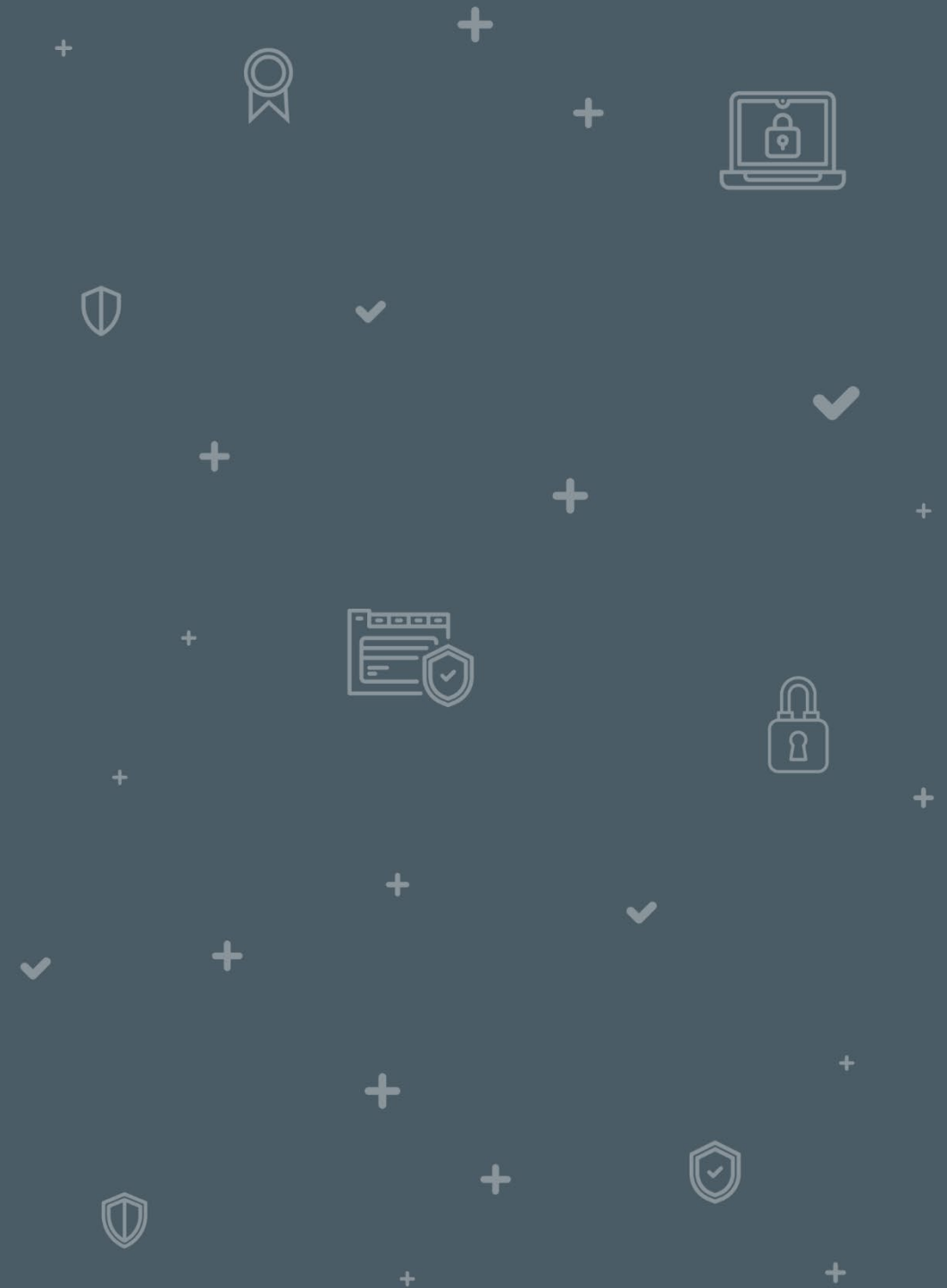
El siguiente gráfico detalla el principio de intercambio de Locard aplicado a la investigación forense digital, en el que se muestra cada uno de los actores involucrados en un delito, así como sus trazas, es decir, tanto el ciberdelincuente como la víctima del ataque siempre van a dejar pruebas de sus acciones cuando sucede un incidente de seguridad.



Fuente propia [Gráfico] Extraído de <https://www.researchgate.net/publication/316427536> La informática forense en dispositivos Android

2

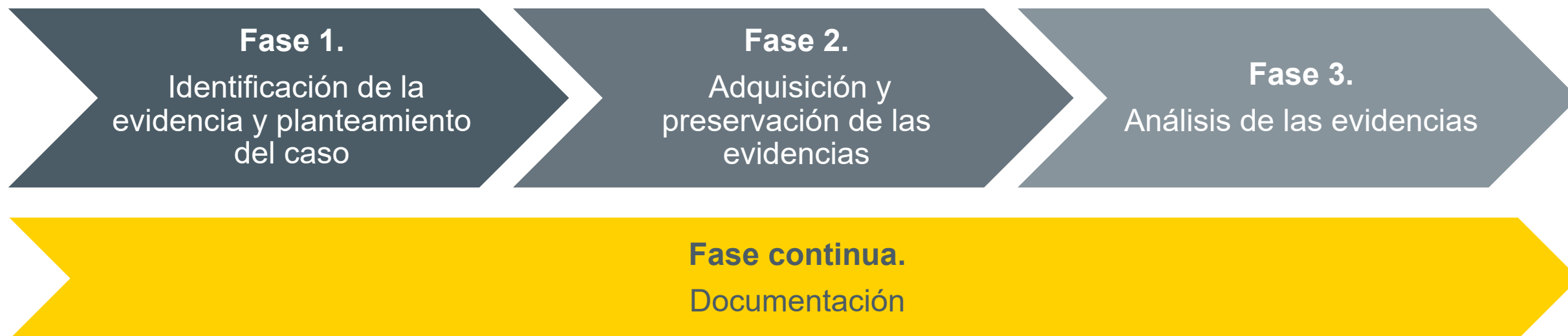
FASES DEL ANÁLISIS FORENSE



FASES DEL ANÁLISIS FORENSE

Introducción

Las fases a seguir durante el procedimiento de una investigación forense son:



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: identificación

La primera tarea que se debe llevar a cabo en un análisis forense digital implica identificar todos los detalles de la investigación. Entre las acciones a tener en cuenta, destacamos:

- **Definir** los objetivos del análisis.
- **Establecer** los antecedentes, situación actual y los motivos por los que se realiza el análisis forense.
- **Identificar** los responsables afectados.
- **Analizar** todos los dispositivos que hayan sido afectados.
- **Definir** las restricciones aplicables, que pueden ser establecidas por el solicitante o por la legislación vigente local, nacional o europea.
- **Iniciar** la cadena de custodia según se tengan en posesión los dispositivos afectados.

2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: identificación

Asimismo, se ha de definir el alcance del análisis forense que se va a llevar a cabo a través de los siguientes elementos en juego:

- **Recursos y personal** disponible para realizar el análisis.
- **Tiempo** que se dispone para realizar el análisis forense.
- **Nivel de detalle** deseado.
- **Restricciones** de accesos a la información, acreditaciones etc.
- **Limitación de ubicación**, como el traslado del equipo.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: identificación

El procedimiento que se llevará a cabo en una investigación forense dependerá del tipo de análisis que se deberá realizar, ya que, aunque haya puntos equivalentes que siempre se realizarán de la misma manera, las diferencias entre diversos casos de investigación no se pueden ignorar si se desea tener un resultado correcto.

El procedimiento se establecerá mediante la metodología de la organización, teniendo en cuenta las capacidades del equipo forense responsable. Además, es muy importante saber que, dependiendo del caso, tal vez sea necesaria la intervención de un analista externo a la organización.

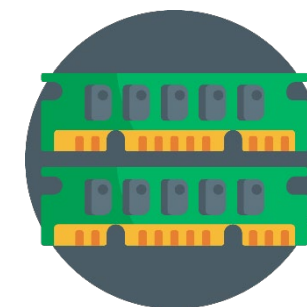
Por último, también será necesario tener datos acerca de la gravedad del incidente, el tipo de incidente y el impacto que este ha tenido en la organización para asignar el tiempo necesario a la investigación forense y proporcionar un equipo adecuado de analistas forenses.

2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: priorización

A la hora de comenzar la investigación forense se deberán tener en cuenta los siguientes puntos para no cometer errores que puedan ocasionar la pérdida de evidencias que podrían resultar vitales a la hora de esclarecer los hechos ocurridos:

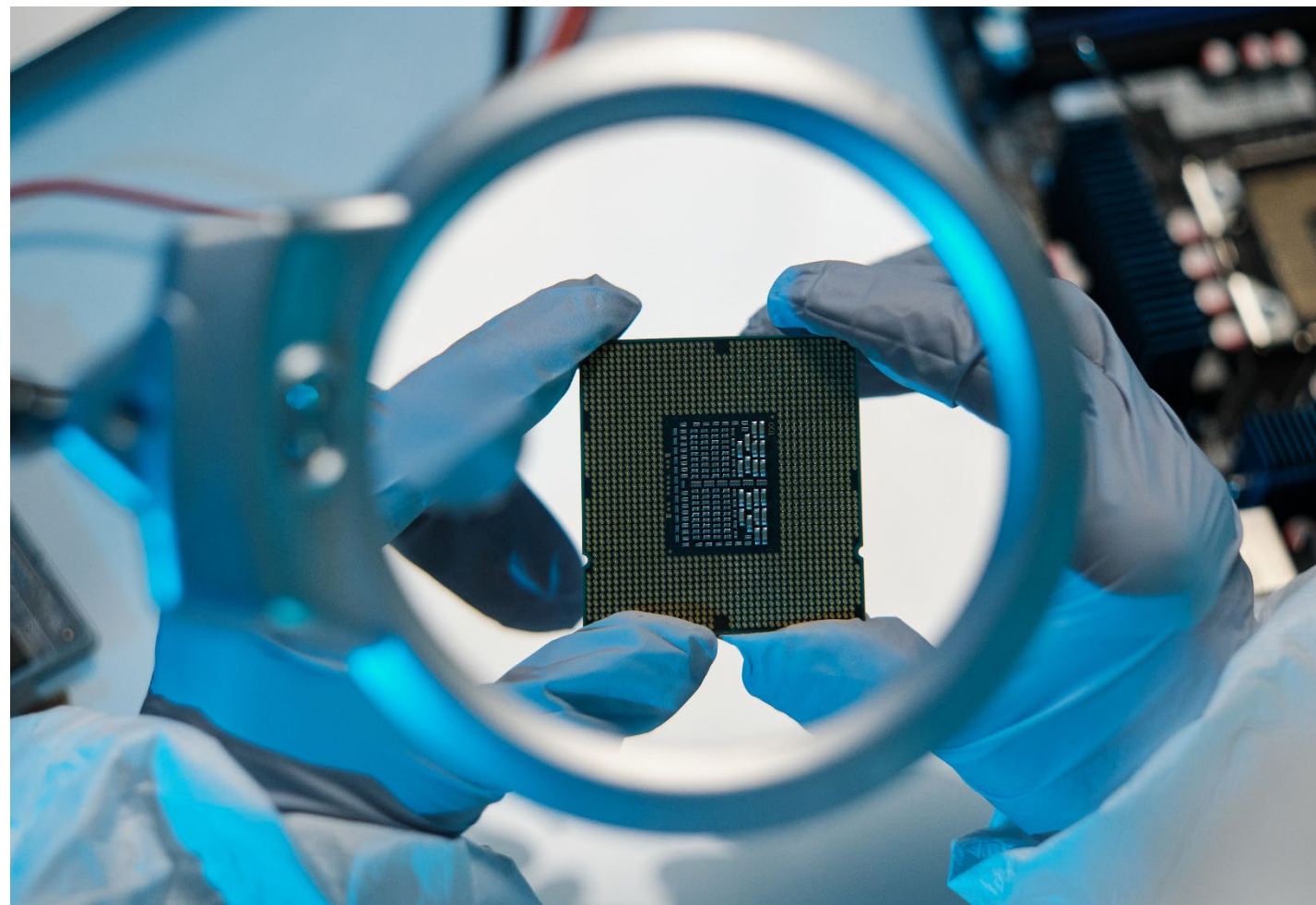
- **Tener en cuenta el tiempo del que se dispone** para realizar el análisis forense y la prioridad que requiere el cliente para obtener la información del análisis.
- **Conocer los diferentes tipos de análisis** que se deberán realizar sobre las evidencias durante todo el análisis forense. Tal vez se deba hacer un análisis de la memoria RAM o un análisis de los *logs* del sistema. Dependiendo de la situación con la que se encuentre el analista, este deberá estar preparado para realizar las acciones que se requieran para poder llevar a cabo el análisis forense de forma satisfactoria.



2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: priorización

- Determinar, de los dispositivos a analizar, **cuáles** nos van a proporcionar un mayor número de evidencias.
- **Analizar los dispositivos que pertenezcan a un individuo primero** antes de empezar con los dispositivos que pertenezcan a un tercero para evitar la posible contaminación de evidencias, es decir, agrupar los dispositivos que pertenezcan a un individuo y analizarlos antes de pasar a analizar los de otro individuo distinto.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: creación de un plan de acción

Una vez se haya definido cuál es el alcance de la investigación, el investigador o el equipo de investigadores que vaya a realizar el análisis deberá definir un plan de acción en el que se especifiquen todas las acciones que se van a llevar a cabo durante las diferentes fases de la investigación para así poder establecer claramente cuál será el procedimiento que estos deberán seguir para que la investigación tenga un resultado satisfactorio.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: creación de un plan de acción

Algunos de los puntos que deberán ser especificados en el plan de acción son:

- Qué evidencias se deberán priorizar durante el análisis.
- Cómo se realizará la adquisición de los diferentes tipos de evidencias.
- Qué instrumentos se utilizarán para obtener estas evidencias.
- Dónde deberán ser preservadas las evidencias.
- Cómo se transportarán las evidencias al laboratorio forense.
- Cómo se mantendrá la cadena de custodia.
- Cuál es el tiempo estimado del que se dispondrá para realizar el análisis.
- Cuáles serán las herramientas que se utilizarán para realizar el análisis de las evidencias.

2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: identificación

Una vez definido el alcance del análisis, se deberá comprobar que se dispone del equipamiento necesario para la correcta realización del análisis. Normalmente, esto no supone un problema, dado que todo equipo de análisis forense debe disponer de todo lo necesario para realizar el análisis, al menos, en los sistemas más comunes.

En muchos casos se deberá realizar la recopilación de evidencias en remoto, es decir, fuera de las instalaciones de los forenses. Por ello, es aconsejable disponer de un **kit de informática forense portable**. Si es necesario analizar un sistema o dispositivo no habitual se deberá contar con las herramientas necesarias para realizar el análisis, así como con personal especializado.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

El analista forense deberá disponer del equipo necesario para la realización de las tareas. Este equipamiento debe ser monitorizado y documentado para asegurar que se mantenga un rendimiento adecuado y solo se deberán utilizar aquellas herramientas y dispositivos que funcionen correctamente y estén en estado óptimo para realizar correctamente sus funciones.

Por otro lado, también se deberá disponer del manual del manufacturado o de los documentos relevantes de cada pieza de equipo. Además, el equipo de creación de imágenes y análisis forense deberá ser validado antes de iniciar la investigación, con el objetivo de que las herramientas utilizadas sean válidas de cara a un proceso judicial.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

En todo proceso de investigación forense digital, en el manejo de las evidencias se debe:

- Mantener el dispositivo en el estado en el que se encuentre, ya sea apagado o encendido.
- Antes de proceder al apagado del dispositivo, considerar si este puede contener evidencias volátiles que podrían borrarse si se apaga el dispositivo. En este caso, se deberán utilizar los métodos forenses apropiados para su captura antes de proceder con el apagado.
- Proveer a los dispositivos de una memoria volátil que deba ser analizada con la electricidad necesaria para que no sufran un apagado antes de que se pueda extraer cualquier evidencia.
- Documentar el estado de los dispositivos que se van a analizar, así como su estado actual, cualquier daño que hayan sufrido, etc. También se deberá documentar cualquier conexión que tenga el equipo y tomar fotografías de todas las partes de los dispositivos.

FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

- Consultar con el investigador jefe qué equipo deberá acudir a la escena de la investigación.
- Leer la autorización pertinente que indica si existe alguna restricción a la hora de recoger las evidencias.
- Si es necesario, recabar evidencias fuera del alcance de la investigación y, en ese caso, se deberá pedir la autorización pertinente para hacerlo.
- Cuando no sea práctico retirar la evidencia de la escena de la investigación, se deberá crear una imagen de la evidencia según los procedimientos de los que dispongamos en la organización.
- Todos los posibles testigos, sospechosos y terceros no deberán, bajo ningún concepto, estar en la proximidad de ninguna evidencia, asegurando así que estos no puedan realizar modificaciones en ninguna de ellas.

FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

- Solicitar información de posibles testigos o sospechosos para obtener un conocimiento importante de los dispositivos que se van a investigar.
- La escena de la investigación se deberá analizar de manera sistemática y en profundidad en busca de posibles evidencias.
- Los investigadores deberán reconocer claramente los tipos de evidencias que se están recolectando y actuar en consecuencia.



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: la cadena de custodia

La **cadena de custodia** hace referencia al protocolo de control de las evidencias que se han obtenido durante una investigación forense, de forma que se garantice la autenticidad, inalterabilidad e indemnidad de las evidencias desde su recolección, hasta su análisis y presentación en un juicio en caso de ser necesario.

Las acciones de la cadena de custodia son:

- ¿Dónde está la evidencia? Listar qué sistemas están involucrados en el incidente y de cuáles de ellos se deben tomar evidencias.
- Establecer qué es relevante. En caso de duda es mejor recopilar mucha información que poca.
- Fijar el orden de volatilidad para cada sistema.
- Obtener la información de acuerdo al orden establecido.

2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: la cadena de custodia

- Comprobar el grado de sincronización del reloj del sistema.
- Según se vayan realizando los pasos de recolección, preguntarse qué más puede ser una evidencia.
- Documentar cada paso.
- No olvidar a la gente involucrada. Tomar notas sobre qué gente estaba allí, qué estaban haciendo, qué observaron y cómo reaccionaron



FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: la cadena de custodia

Para la correcta gestión de la cadena de custodia se deberá asegurar, en cualquier etapa de la cadena que acabamos de ver, la ubicación de las evidencias y documentar quién ha tenido acceso a las mismas.

El no poder mantener una gestión adecuada de la cadena de custodia o el riesgo de que se produzca algún fallo en alguna etapa de la misma causará, automáticamente, la invalidez de las evidencias en un juicio sin importar el grado de relevancia que estas tengan para la investigación.

En el caso de una investigación forense digital, se debe realizar una serie de pasos:

1. En primer lugar, la cadena de custodia se asegurará mediante el cálculo de la función *hash* de cada una de las evidencias. Es importante realizar este cálculo lo antes posible, ya que cuanto más se tarde, menos validez tendrá, por haber habido una ventana de tiempo mayor para que pueda producirse cualquier manipulación.

FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: la cadena de custodia

2. A continuación, se realizará el clonado inicial de la evidencia.
3. Se obtendrá la función *hash* del clonado y se comprobará que coincide con la función *hash* de la evidencia original.
4. Se procederá a crear la cadena de custodia de la evidencia original.
5. Por último, es importante tener en cuenta que debe estar claramente documentada y en todo momento debe detallar los siguientes puntos:
 - ¿Dónde, cuándo y quién descubrió y recolectó la evidencia?
 - ¿Dónde, cuándo y quién manejó la evidencia?
 - ¿Quién ha custodiado la evidencia? ¿Cuánto tiempo? y ¿Cómo la ha almacenado?
 - En el caso de que la evidencia cambie de custodia, indicar cuándo y cómo se realizó el intercambio, incluyendo número de albarán, etc.

FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: la cadena de custodia

Para mantener la gestión de la cadena de custodia de manera rigurosa y garantizar la fiabilidad de las evidencias recopiladas, estas deben:

- Ser correctamente recopiladas.
- Ser correctamente selladas y catalogadas por el equipo de análisis forense.
- Almacenarse de forma adecuada para evitar cualquier tipo de interferencia que pueda afectar a las mismas.
- Recopilarse en un documento donde se especifique cada una de ellas y firmarlo por más de un responsable de la investigación.
- En caso de que se produzca cualquier cambio que afecte a la cadena de custodia de alguna forma, este debe reflejarse en el documento y firmarse por las personas involucradas en dicho cambio.

FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

En la fase de preparación del análisis forense, el analista deberá poseer el conocimiento y la formación adecuada para la realización del análisis. Asimismo, deberá actuar con imparcialidad, integridad y profesionalidad durante su investigación. Por ello, deberá:

- Documentar cada fase del análisis desde el reconocimiento inicial de cada evidencia hasta el informe final.
- Tomar las medidas adecuadas para que ninguna evidencia pueda ser dañada o manipulada. Además, todas las evidencias que se reciban para la investigación forense se deberán examinar y, si se detecta algún fallo en el empaquetado de las mismas, también se documentará.
- Considerar no proceder con la investigación dependiendo del estado de los paquetes con las evidencias.
- No realizar el análisis ni manipulación alguna sobre las evidencias originales, sino únicamente sobre las copias.

2 FASES DEL ANÁLISIS FORENSE

Fase 1: identificación de la evidencia y planteamiento del caso: buenas prácticas

- Hacer uso de bloqueadores de escritura de *hardware* o *software* para evitar que las pruebas puedan modificarse o manipularse.
- Documentar cualquier diferencia del inventario con las evidencias recibidas.



Saber más: Código deontológico de los peritos judiciales. [\[4\]](#)



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: adquisición de evidencias

Durante la fase de adquisición de las evidencias se deberán seguir los protocolos establecidos de preservación, almacenamiento y adecuación:

- **Preservación:** es decir, asegurar la veracidad e integridad de las evidencias adquiridas durante el análisis forense.
- **Almacenamiento:** llevar a cabo el etiquetado de todas las evidencias del caso de la investigación, indicando toda la información relevante de la mismas. Algunos ejemplos serían el tamaño, la fecha de adquisición y la función *hash*.
- **Adecuación:** dado que la investigación puede involucrar ciertos dispositivos que pueden contener información personal y confidencial que no es relevante para la investigación, el investigador debe asegurar de que solo él accede a aquella información relevante para la investigación y que, en ningún caso, se pondrá en entredicho la privacidad ni los derechos fundamentales de los afectados.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: tipos de análisis forense

Existen diferentes tipos de análisis forense que se centran en los principales aspectos de la informática. Algunos de ellos son los siguientes:

- **Análisis forense de base de datos:** consiste en analizar la información que se encuentra almacenada en una base de datos. Este tipo de análisis forense se realizaría en el caso de que se produzca un acceso no autorizado a los servidores corporativos y se sospecha que el atacante hubiera modificado o borrado la información almacenada en los mismos.
- **Análisis forense de correos:** se lleva a cabo un análisis de los datos de los correos electrónicos. Por ejemplo, en caso de un ataque de *phishing*, se analizaría el mensaje del correo electrónico para averiguar quién es remitente, cómo ha enviado el mensaje, qué tipo de enlace ha utilizado para realizar el ataque, etc.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: tipos de análisis forense

- **Análisis forense de *malware*:** el objetivo de este tipo de análisis es conocer el comportamiento de posibles programas maliciosos o *malware*, cómo se instalan en el equipo, qué acciones maliciosas realizan, si se conectan a alguna dirección de Internet, etc.
- **Análisis forense de la memoria:** consiste en requisar el ordenador a analizar y analizar la información contenida en la memoria de este equipo. En este caso, el análisis forense comprobaría el rastro que pudiera haber en el disco duro, la memoria RAM, etc. del sistema.
- **Análisis forense de dispositivos móviles:** se centra en el análisis completo de la información almacenada en los dispositivos móviles, como los contactos, las llamadas, localización, mensajes enviados y recibidos, imágenes, etc. Este tipo de análisis podría utilizarse en el caso de una extorsión a través de redes sociales o aplicaciones de mensajería instantánea.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: tipos de análisis forense

- **Análisis forense de redes:** el objetivo principal es buscar evidencias en el tráfico de red de los dispositivos implicados en un incidente de seguridad, así como en las diferentes herramientas de monitoreo de red que se encuentren en la organización, como los cortafuegos o *firewalls*. Por ejemplo, este análisis se podría llevar a cabo para conocer cómo ha podido acceder un usuario no autorizado al sistema de red o hasta dónde ha intentado acceder, por dónde podría haber entrado, etc. Todo ello con el objetivo de prevenir y reparar ciertas brechas de seguridad, además de contener el ataque en la medida de lo posible.



2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: tipos de análisis forense

Asimismo, debemos tener en cuenta que podemos encontrar dos tipos de análisis forense, que se realizarán en la fase 3, según se realicen con el dispositivo encendido o apagado:

- **Análisis en vivo:** es aquel que se realiza con el dispositivo encendido. Es muy importante, ya que permite obtener la información de la memoria volátil, especialmente de la memoria RAM.
- **Análisis *post-mortem*:** durante este análisis se realiza la copia de la evidencia con el dispositivo apagado.

Si el dispositivo estaba encendido, se debe realizar el análisis en vivo y después una copia del disco duro. Si el dispositivo estaba apagado, no se debe encender para no provocar interferencias en las evidencias.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: firmado de evidencias

En el análisis forense digital, el **firmado de evidencias** se lleva a cabo mediante la función *hash*, el cual nos permite verificar si las evidencias han sufrido algún tipo de manipulación.

Cabe destacar que el análisis forense siempre se realizará sobre una copia de la evidencia original. La evidencia original se mantendrá intacta y, de esta forma, si algo falla durante el análisis o se pone en duda la investigación realizada, siempre se podrá crear una nueva copia y proceder a realizar un nuevo análisis. Esta evidencia original deberá estar debidamente custodiada y protegida. A su vez, si algún individuo intenta destruir las evidencias originales siempre quedarán las copias de las mismas. Para poder verificar si se ha realizado una copia correcta de una evidencia se utilizará, de nuevo, la función *hash* que corroborará que tanto la copia como el original tienen el mismo valor *hash*.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

Una función *hash* permite mapear elementos, como una cadena de longitud fija. Al aplicar la función *hash* a un elemento obtendremos una cadena de caracteres única que servirá como una representación del elemento, es decir, el resultado de la función *hash* aporta un código, esto es, un resumen o un identificador único del elemento sobre el que se aplica la función.

Si la función *hash* aplicada es la misma en todos los casos, por ejemplo, MD5, el valor del código *hash* será diferente para cada uno de los elementos, pero todas las cadenas tendrán la misma longitud.

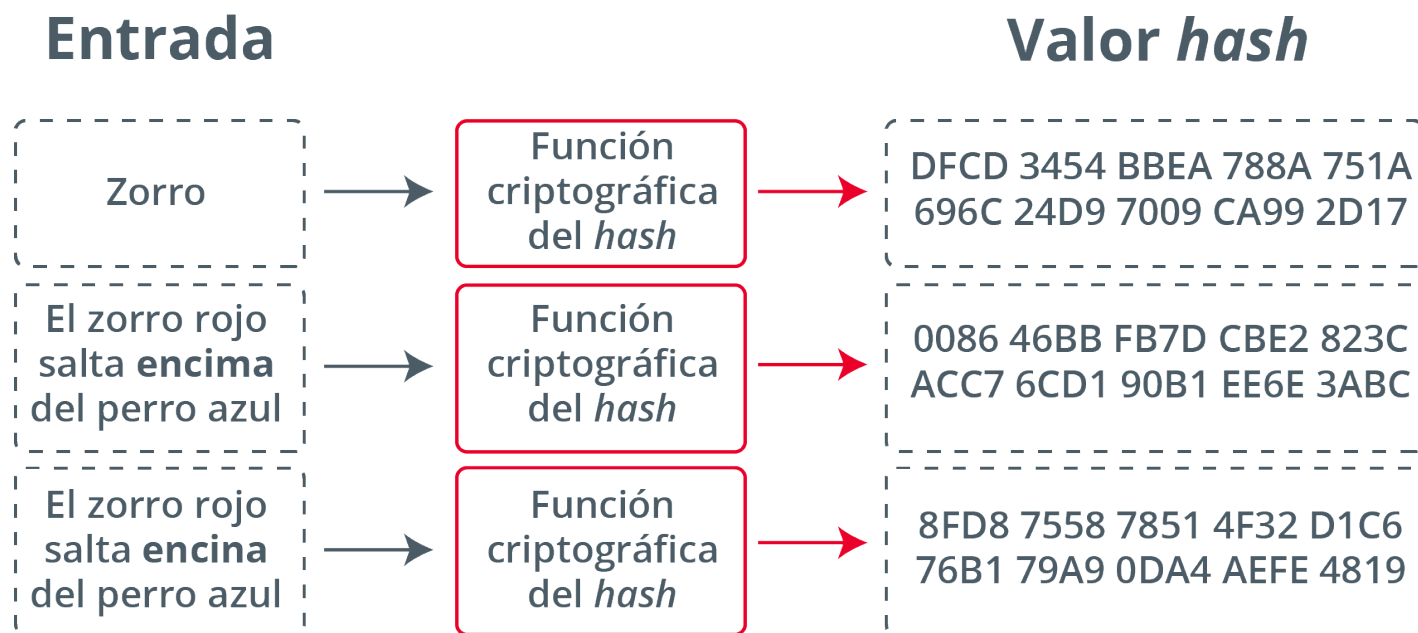
Por otro lado, la función *hash* tiene la característica de que, si se cambia mínimamente el contenido original, el resultado de la función *hash* será un valor completamente diferente al anterior, lo que hace que este tipo de funciones resulten muy útiles para corroborar la integridad de las evidencias, es decir, la función *hash* permite detectar cualquier compromiso de la integridad de la evidencia, ya que cualquier mínimo cambio en el contenido de un fichero produce un valor *hash* completamente diferente.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

Existen diferentes tipos de algoritmos en el proceso de firmado de evidencias:

- **MD5** (1991): comprometidos desde 2004.
- **SHA-1** (1995): comprometidos desde 2005.
- **SHA-2**: en función del rango de salida puede ser un algoritmo SHA-224, SHA-256, SHA-384 y SHA-512.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

La búsqueda de integridad de los contenidos no se realiza únicamente para evidencias digitales, sino que también se emplea en otros ámbitos de la informática como:

- **CRC (del inglés *Cyclic Redundancy Check*) o verificación de redundancia cíclica:** se trata de un algoritmo para la detección de errores, ocasionalmente utilizado como función *hash* debido a su fácil utilización y a que el valor de salida posee una longitud fija.
- **Authentihash:** este algoritmo realiza la función *hash* de la cabecera PE o la cabera del «ejecutable portable» PE, que es donde se almacena la información necesaria para que el sistema operativo Windows pueda administrar el código del ejecutable de un archivo para detectar manipulaciones del mismo, después de que dicho código haya sido firmado por un editor de *software*. Este algoritmo es utilizado por Microsoft App Locker y se ha integrado en diferentes herramientas de seguridad, como VirusTotal o Cuckoo Sandbox.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

Sin embargo, hay veces que lo que se pretende es justo lo contrario, partiendo de que dos contenidos son diferentes, poder comparar rápidamente cómo de similares son. Esto puede hacerse, por ejemplo, para el análisis de diferentes *malware* o también para comparar dos imágenes. En este caso, se emplean un tipo de funciones *hash*, conocidas como *Similarity Preserving Hash Function* (SPHF) o, también, *fuzzy hash*.

Existen diferentes algoritmos de *fuzzy hash*, como:

- **Ssdeep/sdhash**: se trata de un algoritmo del tipo *fuzzy hashing* que genera *hashes* de bloques y secciones de bits, permitiendo así detectar ficheros que tengan multitud de similitudes, pero que varían ligeramente. Por ello, el uso de algoritmos de *hashing* comunes no sería efectivo, es decir, se dividirá el archivo en grupos iguales de bytes (grupos de 8 bits) y sobre cada uno de ellos se calculará un *hash*. A partir de todos ellos, se generará un nuevo *hash* que representará al archivo. Este último *hash* es el que permite comparar similitudes con otros archivos. Haz clic aquí para ver, con un ejemplo, cómo funciona el algoritmo Ssdeep/sdhash. [\[5\]](#)

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

- **vHash:** es un algoritmo perteneciente a VirusTotal, cuyo objetivo es encontrar archivos similares dentro de su base de datos.
- **Imphash:** se trata de un algoritmo que se utiliza para la identificación de muestras de *malware* relacionadas entre sí.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: la función *hash*

Veamos ahora cómo funciona *hash* y *fuzzy hash* con un ejemplo. Para ello, vamos a utilizar SHA-256 para el cálculo del *hash* y Ssdeep para *fuzzy hash*. Creamos un archivo de texto .txt de título «Unidad5_Análisis_Forenses» y con el siguiente texto «Unidad5_Análisis_Forenses» y, a continuación, calculamos su *hash* y su *fuzzy hash*:

Hash: 33f2e9cdcdc59f4416de926c598129de0a7ca0577c206716139e7b0afbb71fa1
Fuzzy hash: 3:+M3JXXnALWA:+6XuWA,"Unidad5_Análisis_Forenses.txt"

Si ahora modificamos el texto del archivo ligeramente por «Unidad4_Análisis_Forenses» y volvemos a generar el *hash* y *fuzzy hash*, los resultados obtenidos son los siguientes:

Hash: 37c48cebbfa8b2651ef3bcbebb6bc0805804b1a49a69b182d4414c964c377614
Fuzzy hash: 3:+AgXXnALWA:+fXuWA,"Unidad5_Análisis_Forenses.txt"

Podemos ver que los *hashes* son completamente diferentes, mientras que los *fuzzy hashes* tienen algunas similitudes.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

Antes de comenzar el análisis forense, se deberán realizar varias tareas para asegurar que se cumplen todos los requisitos legales y contractuales, como:

- La verificación de que la cadena de custodia se ha cumplido debidamente.
- La comprobación de que se dispone de un laboratorio que cumple con las necesidades para realizar el análisis debidamente y con un control de acceso que solo permita el acceso al personal autorizado, en este caso, el investigador o analista forense.
- La confirmación de que se dispone de un almacenamiento seguro y con control restringido de acceso.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

En un caso de infección por *malware*, antes de comenzar a manipular los dispositivos infectados, ya sea para la búsqueda de evidencias y su posterior análisis o para recuperar el contenido almacenado en su interior, es necesario llevar a cabo una serie de medidas de seguridad básicas para asegurar que no se ponen en riesgo otros sistemas o que la infección se expande:

- **Verificar** que los equipos infectados han sido identificados y se encuentran aislados y en cuarentena, además de asegurar que no están conectados a ninguna red interna o externa. Por otro lado, garantizar que ningún otro dispositivo secundario se ha visto afectado, por ejemplo, un disco extraíble o una memoria externa USB.
- **Identificar** que todos los dispositivos afectados estén almacenados de forma de segura para evitar su pérdida o que se haga un uso indebido de ellos.
- Por último, **desactivar** los antivirus y otras medidas de seguridad para evitar que interfieran durante el análisis forense.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

Una vez que nos hemos asegurado de que la infección no se puede propagar más, el siguiente paso es obtener la información necesaria para determinar qué es lo que ha ocurrido.

En esta fase solo nos encargaremos de obtener las evidencias del dispositivo para que este que nos ayude a saber qué es exactamente lo que ha sucedido o las causas que han originado la incidencia. Al trabajar con un equipo infectado, debemos utilizar un dispositivo de «solo lectura» y las herramientas adecuadas para evitar un contagio mayor.

Por otro lado, las evidencias se obtendrán y almacenarán siguiendo un procedimiento forense que garantice su validez y adecuado almacenamiento, permitiendo así que cualquier resultado pueda ser comprobado.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: evidencias volátiles

A la hora de adquirir evidencias, estas se pueden agrupar en dos categorías principales:

- **Evidencias volátiles:** son aquellas evidencias que se perderían si el equipo a analizar fuese apagado. Por lo tanto, deberán ser recogidas antes de apagar el equipo, es decir, con el ordenador encendido. En el caso de que se encuentren en la memoria RAM, se podrá hacer un volcado de la memoria (*memory dump*, en inglés) para recoger las evidencias.

Por otro lado, si las evidencias se encuentran almacenadas en ficheros temporales dentro del disco duro, se debería desconectar el sistema de golpe, es decir, evitando un apagado correcto o habitual y cortando de forma brusca el suministro eléctrico, habitualmente desenchufando el cable de alimentación, lo que vulgarmente se conoce como «tirar del cable», lo que nos asegurará que los ficheros temporales no serán borrados durante el cierre del sistema. Para evitar interferencias en el sistema se deberán utilizar herramientas portátiles desde un dispositivo externo de almacenamiento.



Memoria RAM

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: evidencias no volátiles

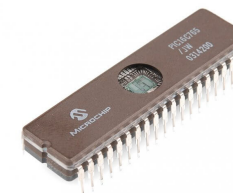
- **Evidencias no volátiles:** hacen referencia a las evidencias que no se perderían al apagar un sistema. Algunos ejemplos de evidencias no volátiles serían el disco duro, una tarjeta de memoria o la memoria ROM, que permite almacenar datos e información del sistema, de la configuración, programas, etc. En este caso, no sería necesario extraer las evidencias hasta que los dispositivos que se vayan a analizar lleguen al laboratorio forense, dado que el apagado del equipo o la desconexión de la red a la que este está conectado no va a resultar condicionante en la pérdida de estas evidencias.



Fuente: *Disco duro*. Extraído de:
<https://www.crucial.es/articles/pc-builders/what-is-a-hard-drive>



Fuente: *Memoria USB* [Captura de pantalla] Extraído de:
<https://www.mytrendyphone.es>



Fuente: *Memoria ROM*.
Extraído de: <https://gamerpc.es/memoria-rom/>

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: volatilidad de la memoria

Uno de los aspectos a destacar de la memoria, como hemos visto, es que esta puede clasificarse según sea o no volátil. Sin embargo, podemos realizar una clasificación de los tipos de memoria según su volatilidad. Esto permite acotar inicialmente el trabajo del analista forense, comenzando desde la evidencia más volátil hasta la menos volátil.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

En la fase de adquisición de evidencias, se han de **clonar bit-a-bit** todos los dispositivos involucrados en una investigación para proceder a su posterior análisis, para no arriesgar la integridad de los mismos, garantizando así la veracidad de las evidencias y, si fuese necesario, la posibilidad de la repetición de las pruebas. Para realizar este tipo de clonado se ha de considerar que, si el análisis va a constituir una prueba en un juicio, será obligatorio la presencia de un notario que valide este proceso y la veracidad de la copia que se haga del equipo.

Se debe realizar este tipo de clonado bit-a-bit debido a que es el único que permite obtener una copia exacta del disco duro para realizar el análisis forense. La principal característica del clonado bit-a-bit es que permite recuperar, incluso, archivos borrados de forma virtual del disco. Asimismo, se deberá tener un disco duro con las mismas especificaciones que el que se vaya a clonar completamente *wipeado*, es decir, que todos los bits del disco estén a 0, para así evitar que el contenido del clonado sea modificado de alguna forma.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

El tiempo que tarde en copiarse un disco dependerá del tamaño del disco, del contenido que tenga y de la velocidad de clonación que disponga. A modo orientativo se podría decir que un disco de un terabyte puede tardar unas tres horas en clonarse.

Asimismo, se deberán realizar como mínimo tres copias, teniendo en cuenta que el dispositivo original se mantendrá bajo custodia para garantizar la integridad del proceso: una copia para la organización, otra copia para la víctima o el responsable que ha solicitado el análisis, y una última copia para el investigador o el perito forense.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

- **Clonado de disco duro:** como hemos indicado en la anterior diapositiva, este proceso implica la copia bit-a-bit de toda la información contenida en el disco duro en otro disco duro considerado como copia, lo que implica que, por cada disco a copiar se necesita otro disco duro de destino que posea las mismas características que el original. Por ejemplo, si necesitamos clonar un disco duro de una determinada marca y con unas características específicas, necesitaremos otro disco duro con estas mismas características para realizar la copia. En algunos casos, para clonar un equipo se podrá utilizar una clonadora y la herramienta más destacada para ello es OSFClone (*open source*).

En el caso de que se extraigan ficheros sospechosos de un disco duro en concreto, que podrían estar comprometidos con *malware*, y del cual desconocemos tanto sus características como sus capacidades, se deberá tener especial cuidado en el proceso de adquisición de evidencias. Por ello, se recomienda el almacenamiento de los ficheros en un contenedor cifrado, por ejemplo, un archivo .zip, cifrado con contraseña para impedir que se haga un uso de manera accidental o indebido de este tanto por parte de un empleado como por alguna aplicación.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

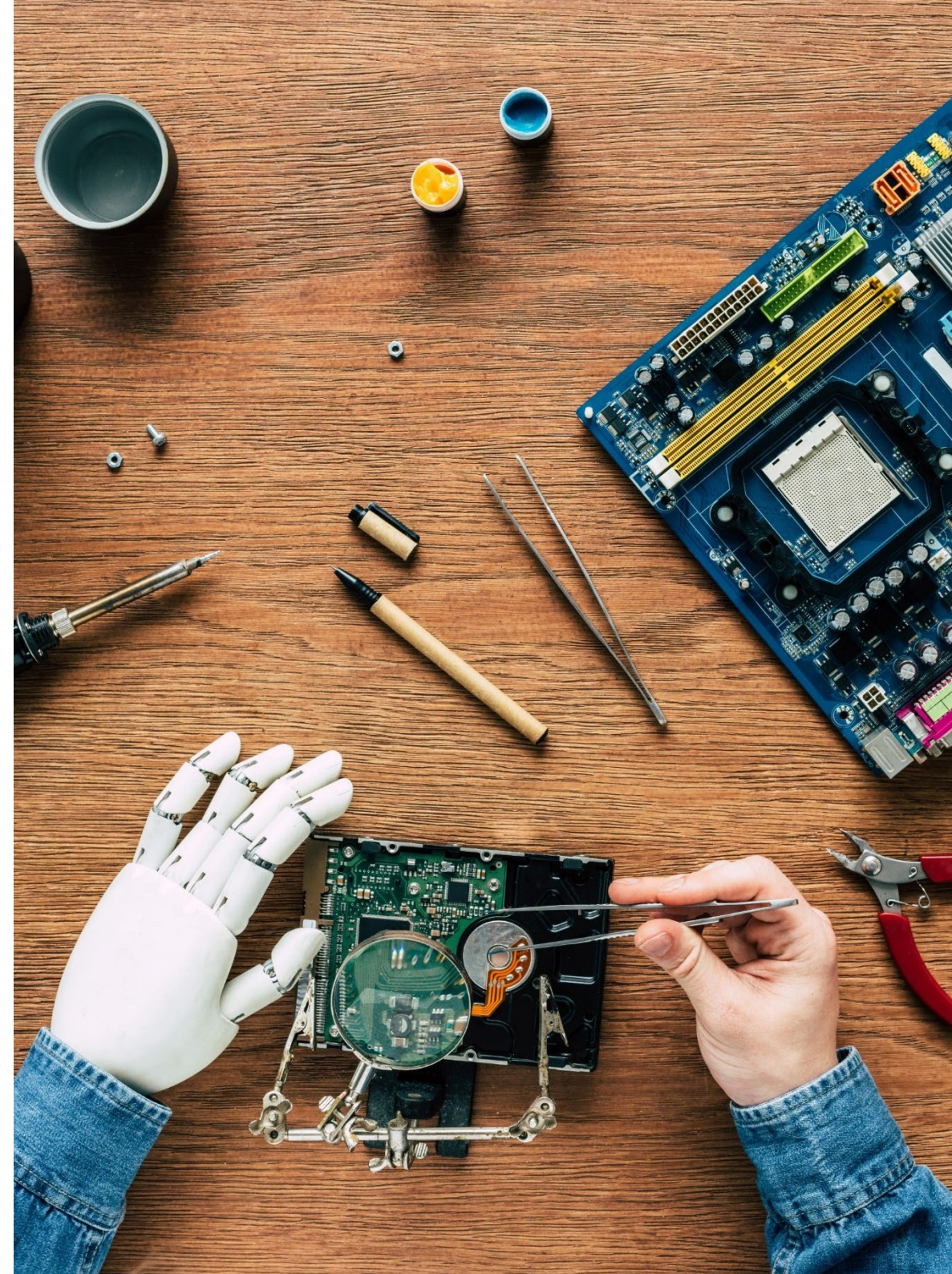
- **Imágenes forenses de un disco duro:** consiste en empaquetar toda la información que contiene un disco duro en un archivo con un formato .ex, .dd, .iso o .raw, es decir, diferentes tipos de extensiones en las que se puede realizar una réplica del disco duro. Al igual que con el proceso de clonado, en la réplica de las imágenes forenses se podrá verificar la integridad de las evidencias mediante el *hash* del fichero de la imagen mediante las herramientas Guymager, FTK Imager o EnCase Forensic.

La diferencia esencial entre la creación de una imagen de un disco duro o el clonado de este radica en que, para realizar el clonado se necesita un disco duro o una partición de un disco al que mandar la copia del que queramos clonar, mientras que para la creación de una imagen simplemente se creará una copia en uno de los formatos disponibles del disco duro.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias

Una ventaja clara de la creación de una imagen es que se puede realizar de manera virtual sin la necesidad de disponer de un disco duro externo, pudiendo trabajar de manera remota con esta, por lo que es útil si las distancias entre las pruebas y el analista es muy amplia, ya que el analista simplemente pediría que le enviaran una imagen del disco. La creación de una imagen también tiene sus inconvenientes, dado que puede verse más susceptible de ser modificada de alguna forma que el clonado de un disco duro, lo cual podría provocar que las pruebas se alterasen haciéndolas posiblemente inservibles.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: metadatos

Los metadatos hacen referencia a todos aquellos datos que aportan información sobre un archivo concreto, por ejemplo, cómo y cuándo se creó un fichero determinado, cuándo fue modificado o si se accedió al mismo, así como otra información que pueda ser utilizada para describir un archivo. Cualquier tipo de archivo, como puede ser un documento PDF, una imagen o un vídeo, tendrá metadatos.

Los metadatos pueden clasificarse en:

- **Metadato descriptivo:** aquellos metadatos que describen el contenido del dato y suelen incluir información, como el título, el autor, etc.
- **Metadatos estructurales:** se trata de aquellos que describen las relaciones que existen entre diferentes datos y cómo están siendo estructurados. También incluyen información acerca de páginas, secciones, capítulos, numeración, etc.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: metadatos

- **Metadatos administrativos:** estos facilitan la información acerca de propiedad del dato, los derechos de autor y la información técnica general acerca de la propiedad del dato.

Los metadatos son un importante componente de la gestión de datos debido a cómo se utiliza la información hoy en día. Actualmente, estamos constantemente rodeados de una gran cantidad de datos que deben ser correctamente tratados por las aplicaciones de las que disponemos y que deben saber qué datos les pertenecen y cuáles no, y cómo utilizarlos.

Los metadatos son evidencias relevantes para una investigación forense, ya que permiten a un analista forense comprender los diferentes cambios que ha sufrido un dato desde su creación hasta su estado actual, es decir, hacen referencia a las trazas o el historial de un dato. Por ejemplo, en el caso de que un dispositivo móvil haya hecho una foto, en los metadatos de la imagen posiblemente podríamos encontrar la fecha en la que se sacó esa foto, el autor de la foto y la ubicación en la que se hizo.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: metadatos

Los metadatos pueden ser visibles o no visibles. Los metadatos visibles son aquellos que se pueden encontrar haciendo clic en el botón derecho del ratón sobre un fichero que nos dará la información sobre el tipo de fichero, su tamaño, cuándo fue creado, cuándo fue modificado, etc. Por otro lado, los metadatos no visibles son aquellos que se deberán extraer con herramientas forenses e indican la información de seguridad de un fichero.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: obtención de la información

Data carving es una técnica de recuperación de datos borrados que utiliza solo los espacios no asignados de memoria. Como hemos visto, se pueden recuperar los datos que hayan sido borrados mediante la selección de un archivo que tenga la etiqueta de borrado, ya que, en realidad, no se borra la información del archivo, sino que el espacio en el que se encuentra el fichero se marca para ser sobrescrito por la memoria. Esta técnica es muy útil a la hora de recuperar datos que hayan sido perdidos o corrompidos.

La diferencia entre las técnicas de recuperación de datos y *data carving* es que las primeras se centran en la restauración de datos utilizando la información que le proporciona el sistema de archivos para recuperar los datos, y el método de *data carving* no utiliza ninguna información sobre la estructura del sistema de ficheros, sino que trabaja con los datos directamente.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: obtención de la información

El *data carving* tiene una serie de inconvenientes a tener en cuenta:

- **El desconocimiento del tamaño exacto del fichero que se desea recuperar:** la gran mayoría de las aplicaciones que permiten realizar *data carving* necesitan conocer el tamaño exacto del fichero para realizar correctamente la recuperación de los datos. Como alternativa, se podría utilizar la información del encabezado del archivo para recuperar la información acerca de su tamaño, aunque hay que tener en cuenta que algunos metadatos no tienen esta información, por ejemplo, los archivos .jpeg.
- **Las limitaciones de las aplicaciones para la recuperación de archivos:** muchas aplicaciones tienen limitaciones en el tamaño máximo del archivo que se desea recuperar.
- **El encabezado del fichero a veces no contiene información acerca del tamaño del fichero,** lo que dependerá del tipo de fichero. Por ejemplo, los ficheros .jpeg no suelen contener esta información.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas forenses

En una investigación forense digital se utilizan diferentes herramientas que pueden aportar información valiosa durante el proceso de análisis, como las herramientas *hardware* y *software*. Las herramientas *hardware* se centran en mantener el contenido del dispositivo que se esté analizando intacto, mientras que las herramientas *software* se encargan de analizar y recoger las evidencias que se necesitan para la investigación.

Los ciberdelincuentes, habitualmente, esconden sus archivos o crean particiones de su disco duro, que consiste en dividir la capacidad de almacenamiento de un disco en varias secciones, provocando así que sea complicado encontrar esas evidencias. Aquí es donde entran en juego las herramientas de *software* que nos permiten recuperar todas las evidencias.

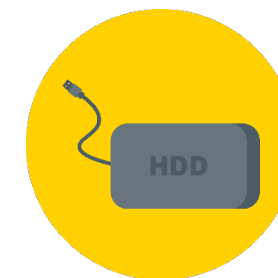


2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas *hardware*

Un investigador podrá utilizar diferentes equipamientos *hardware* para realizar la investigación forense, como:

- **Una memoria externa o USB de recuperación:** se encargará de recuperar los archivos borrados incluso si los archivos han sido eliminados de la papelera de reciclaje, debido a que, como hemos comentado, esta acción no es definitiva, sino que el sistema etiqueta al archivo para que pueda ser sobrescrito por otros archivos nuevos una vez que se hayan creado. Por otro lado, también se podrían recuperar los archivos de un disco duro formateado mientras el disco duro no haya sido utilizado, es decir, creando nuevos archivos. Así, se podrían recuperar los punteros, estos son, variables que identifican a cada archivo y que apuntaban a los archivos borrados.
- **Una memoria externa o USB de recuperación para dispositivos Apple:** este tipo de memoria funciona de manera similar al recuperador de memoria externa o USB tradicional, pero, en este caso, está orientada específicamente para analizar los productos o dispositivos de la marca Apple.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas *hardware*

- **Duplicador de discos duros:** se trata de un dispositivo que copia todos los archivos del disco duro objetivo a un nuevo disco duro limpio. También puede duplicar los datos de memorias *flash* que tienen la capacidad de leer y escribir varias posiciones de la memoria en la misma operación, lo que le permite ser más eficiente que otras memorias extraíbles, como SSD.
- **Recuperador de contraseñas:** hace referencia a un dispositivo que emplea algoritmia para intentar averiguar la contraseña de los dispositivos de almacenamiento. Algunos de los algoritmos que puede utilizar para penetrar en el equipo son, por ejemplo, los ataques de fuerza bruta o ataques de diccionario.
- **Protector de escritura de un disco:** este dispositivo impide que el contenido de un disco duro pueda ser modificado o borrado.
- **Un controlador de disco forense:** se trata de un dispositivo de «solo lectura» que permite al usuario leer los datos del equipo objetivo, pero sin acceso a la modificación o el borrado de algún archivo.

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas *hardware*



Clonadora

Fuente: *Clonadora de discos*
[Captura de pantalla] Extraído de:
<https://indalics.com/>



Bloqueador de escritura

Fuente: *Bloqueador de escritura*
[Captura de pantalla] Extraído de:
<https://encrypted-tbn0.gstatic.com>



Bolsa de Faraday Fuente: *Bolsa de Faraday* [Captura de pantalla]
Extraído de:
<https://encrypted-tbn0.gstatic.com>

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas *hardware*



Cables y adaptadores

Fuente: *Cables y adaptadores*
[Captura de pantalla] Extraído de:
<https://onretrieval.com>



Discos duros

Fuente: *Discos duros* [Captura de
pantalla] Extraído de:
<https://encrypted-tbn0.gstatic.com>



Memorias extraíbles USB

Fuente: *Memorias USB* [Captura
de pantalla] Extraído de:
<https://m.media-amazon.com>

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: herramientas *hardware*



Tarjetas de memoria

Fuente: *Tarjetas de memoria* [Captura de pantalla] Extraído de:
<https://i.blogs.es>



Sobres y etiquetas

Fuente: *Sobre y etiquetado* [Captura de pantalla] Extraído de:
<https://encrypted-tbn0.gstatic.com>

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: directorio de herramientas

A pesar de que existe una serie de distribuciones o kits de herramientas *open source* especializadas en el análisis forense que conoceremos con más detalle a lo largo de esta unidad, lo recomendable es contar con un directorio de herramientas de acuerdo a las necesidades, aquí puedes encontrar algunas de ellas [6]. Las más recomendables son las siguientes:

Distribuidor de herramientas	Referencia
Caine	https://www.caine-live.net/
Helix Live CD	https://www.e-fense.com/
The Sleuth Kit/Autopsy	https://www.sleuthkit.org/
SIFT (SANS DFIR)	https://digital-forensics.sans.org/community/downloads

2 FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: recogida de dispositivos

En este apartado observaremos las diferencias que surgen cuando nos encontramos un equipo encendido o apagado y, en el caso de estar encendido, si este se encuentra conectado a la Red o no. Todo esto hará referencia a las buenas prácticas que se deben realizar a la hora de recoger el dispositivo:

- **Si el dispositivo se encuentra encendido**, se deberá comprobar si este se encuentra conectado a la Red. Si es así, se deberá desconectar de esta para evitar que se traspasen ficheros del equipo o que se modifique algún fichero a través de Internet, por ejemplo, si tiene un troyano instalado o forma parte de una *botnet* donde el ordenador recibe instrucciones de un atacante remoto. Tras esto, se deberá proceder de manera habitual: extraer las evidencias volátiles y una vez hecho esto retirar el cable de alimentación de la parte trasera del equipo y colocar la cinta de evidencias en el conector del cable de alimentación.

FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: recogida de dispositivos

Colocar la cinta de evidencias sirve para prevenir que se vuelva a conectar a la red eléctrica cuando no es debido. Se trata de una buena práctica. Después se desconectará la batería del ordenador para realizar un apagado sucio del dispositivo para que se pierdan menos evidencias de las que se perderían haciendo un apagado normal.

- **Si el dispositivo no está encendido**, deberemos desconectar todos los cables de energía del dispositivo y retirar la batería de los portátiles, así como colocar una cinta de evidencias en el conector del cable de energía. De este equipo no podremos aprovechar las evidencias volátiles, así que esencialmente el análisis se hará sobre las evidencias contenidas en el disco duro.



FASES DEL ANÁLISIS FORENSE

Fase 2: adquisición y preservación de las evidencias: recogida de dispositivos

En el caso de que el dispositivo sea un **servidor**:

- Se deberá hacer una estimación de cuántos datos deberán ser recolectados para la investigación.
- Obtener evidencias volátiles, si es necesario.
- Si se debe producir un apagado, seguir los procedimientos adecuados.
- Se deberá tener especial cuidado con el manejo de las evidencias y su transporte para mantener la cadena de custodia, especialmente a la hora de transportar evidencias electrónicas, para evitar daños físicos, vibraciones o cualquier efecto electromagnético que pudiese dañarlas y cualquier condición climática que las pudiese alterar.



FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: técnicas

Existen numerosas técnicas de análisis que se pueden utilizar a la hora de hacer un análisis forense. Estas técnicas permiten acceder a datos que no se podrían obtener de ninguna otra forma, por ejemplo, a los datos eliminados, a las carpetas ocultas, descodificar datos encriptados, etc. A continuación, se detallan algunas técnicas más relevantes:

- **Recuperación de archivos eliminados:** se utiliza para recuperar archivos que se hayan borrado del dispositivo que se está investigando. Cuando un usuario borra un fichero, este archivo no se borra realmente, sino que en el espacio de disco que ocupaba, se realiza una marca que indica que se puede escribir en él. Por lo tanto, es posible recuperar estos ficheros borrados si no se ha almacenado información nueva en ese espacio de disco.
- **Recuperación de archivos ocultos utilizando esteganografía:** la esteganografía es una técnica que se lleva a cabo para la ocultación de datos dentro de otros ficheros, imágenes, mensajes y flujos de datos mediante criptología y así no puedan ser detectados a simple vista. Aunque esta técnica es muy compleja, un analista forense puede comprobar el *hash* del fichero original para poder detectar cualquier cambio que se haya producido en el archivo.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: técnicas

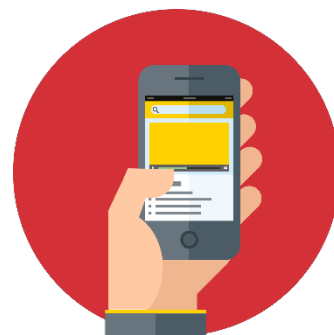
- **Análisis forense estocástico:** es una técnica de análisis forense que se centra en reconstruir la actividad que se ha realizado en un ordenador sin que haya artefactos. Los artefactos son alteraciones no intencionadas o no deseadas que pueden producir los procesos digitales, ya sea por una técnica y/o tecnología involucrada. Partiendo del punto de vista estocástico, se considera que un sistema informático actual puede ser demasiado grande y complejo para ser analizado por completo. Sin embargo, a pesar de ser complejo, tiene propiedades probabilísticas bien definidas. Al analizar las propiedades estadísticamente, la mecánica estocástica puede deducir qué hechos sucedieron, incluso si no se genera ningún artefacto.



2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: técnicas

El análisis forense estocástico se emplea, generalmente, en la investigación de robo de datos internos. Dado que el robo interno de datos se realiza por un empleado de la empresa que tiene un acceso autorizado a los mismos, su acceso a esta información no genera ningún artefacto, al considerarse una actividad normal. Por este motivo, este tipo de ataques apenas dejan algún rastro. Sin embargo, la distribución estadística de los metadatos sí cambia porque se pasa de registrar gran cantidad de accesos pequeños a un único acceso a mucha información, de tal manera que, si se analiza esa distribución, sí podríamos comprobar que se ha producido un ataque de esta clase.



FASES DEL ANÁLISIS FORENSE

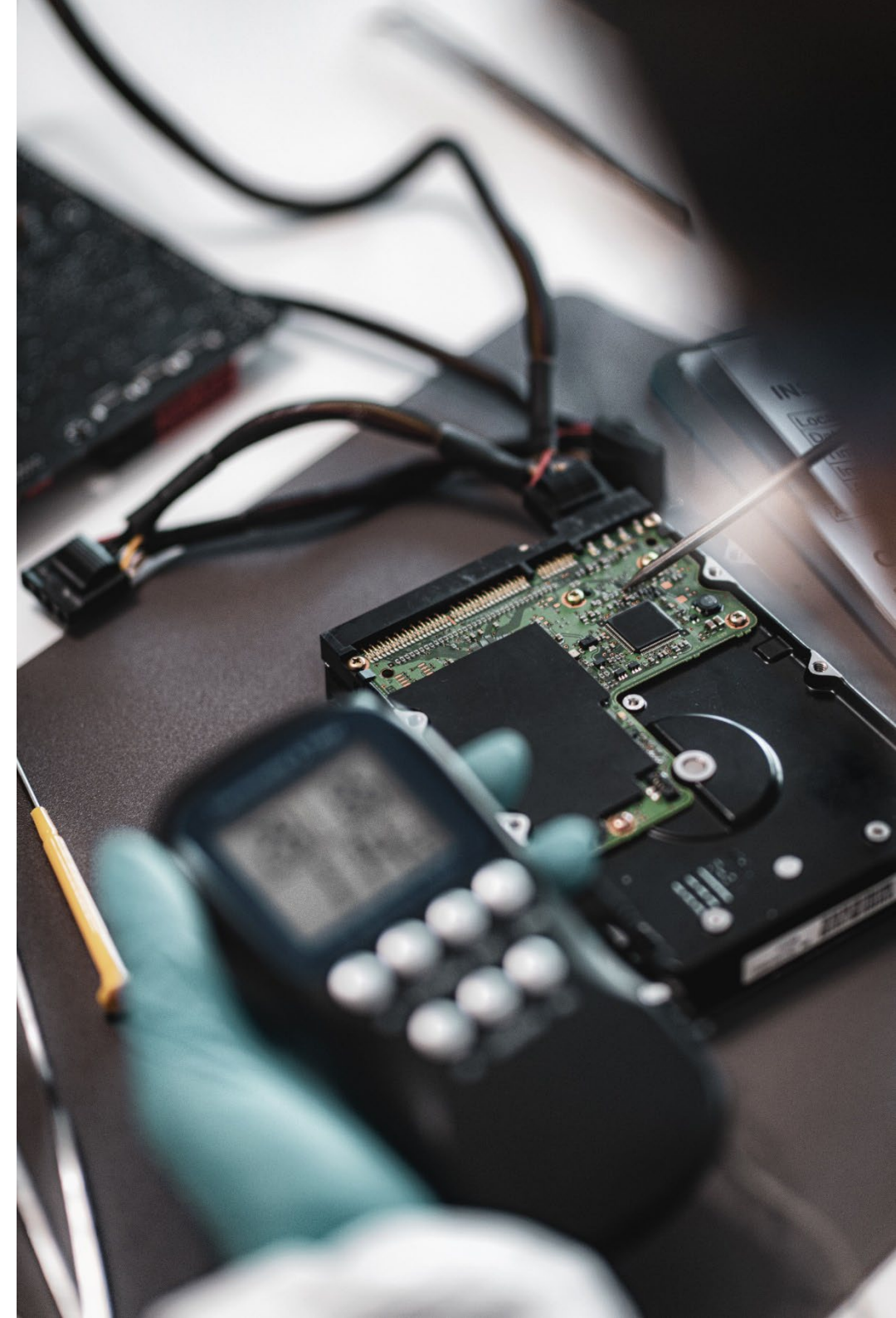
Fase 3: análisis de las evidencias: técnicas

- **Extracción de características forenses (FFE, del inglés *Forensic Feature Extraction*):** este método se centra en el uso de técnicas lexicográficas, es decir, en la utilización de identificadores que sirvan para buscar datos que puedan concordar con algunos de los datos que se encuentren en una imagen de un disco duro y sean posibles evidencias. A los identificadores se les denomina «características» (*features*, en inglés). Por ejemplo, se utiliza en tarjetas de crédito.
- **Análisis cruzado de discos (CDA del inglés *Cross-Drive Analysis*):** se centra en la correlación de la información encontrada en diferentes discos duros de varios equipos para buscar, recuperar y analizar toda la información relevante para la investigación forense. La información que se considere relevante se comparará con la encontrada en otros discos duros para comprobar qué similitudes existen. Esta técnica se suele emplear usando también FFE, aunque FEE puede usarse para un único ordenador.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: técnicas

- **Análisis en vivo:** en este caso, se lleva a cabo un análisis en el escenario donde ha tenido lugar la incidencia, es decir, se centra en analizar las evidencias volátiles o temporales del dispositivo. Estas son evidencias que se eliminarán si el dispositivo cambia de estado, extrayendo la información de la caché y de la memoria RAM para ser procesada. Existen numerosas herramientas para el análisis de evidencias volátiles, como Volatility.



FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos

Los artefactos son los diferentes ficheros, rutas de acceso o configuración que pueden determinar la actividad de un *malware* o de un usuario malicioso en un sistema y se estudian y emplean como evidencias para constituir una prueba. Dicho de otra forma, los artefactos son los ficheros, registros de actividad, configuraciones, etc. que generan los sistemas operativos para registrar toda la actividad que se ha producido en el equipo, y que en informática forense se consultan en busca de indicios y pruebas de qué ha sucedido y cómo. Así, un artefacto puede ser:

- Los *logs* o ficheros de sistema.
- La tabla maestra de archivos MFT.
- El registro de Windows.
- El visor de eventos.
- Los ficheros Prefetch.
- Los accesos directos.
- La papelera de reciclaje del equipo.
- Los metadatos de las imágenes.
- Los ficheros de hibernación y memoria del dispositivo.
- Las copias de seguridad o *backups*.
- Las *volume shadow copies* o sombras de volumen.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Windows

A la hora de recopilar artefactos debemos tener en cuenta que la gran mayoría de ordenadores utilizados actualmente son equipos que utilizan el sistema operativo Windows. Por ello, resulta relevante identificar y conocer cuáles son los diferentes artefactos que podemos obtener de Windows. Estos son:

- **La papelera de reciclaje:** este programa es uno de los artefactos más importantes que se pueden encontrar en el sistema operativo Windows, ya que podemos obtener una gran cantidad de información de él, puesto que es donde se almacenan los archivos que el usuario ha borrado de su equipo, pero que aún no han sido borrados por el sistema. Además, aunque el archivo haya sido borrado completamente del sistema, el investigador todavía puede obtener información importante de este programa como la ruta original del archivo, así como el momento temporal en que fue enviado a la papelera.



Saber más: Artefactos de Windows y ruta de artefactos (pág. 80). [\[7\]](#)

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Windows

- **Notas:** en este programa se puede encontrar información relevante que el usuario haya guardado en algún momento, como algunas credenciales de acceso o posibles rutas de ficheros confidenciales.
- **Archivo de registro:** se trata de una base de datos que almacena detalles sobre las configuraciones que se hayan hecho en el sistema operativo, la actividad del usuario y el *software* que haya sido instalado previamente en el dispositivo.
- **Actividad del usuario:** el fichero «ntuser.dat» almacena la actividad de todos los usuarios que contenga el dispositivo, lo que proporcionara una visión de todas las actividades que un usuario específico haya llevado a cabo en un equipo.
- **Fichero Prefetch:** siempre que un programa se ejecuta por primera vez en un equipo, el sistema operativo crea este tipo de archivo, que podría indicar a un investigador la hora determinada a la que se ha ejecutado y desde qué ruta específica. Este tipo de ficheros continúa existiendo aun después de borrar el programa ejecutado.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Windows

- **Logs de eventos:** Windows almacena información muy relevante en estos *logs* para una posible investigación, como podría ser el caso de determinar cuándo se ha iniciado sesión en un equipo, cuándo se ha encontrado una incidencia en un programa, los diferentes eventos de alguna aplicación o accesos por RDP (del inglés *Remote Desktop Protocol*) o cuándo se ha realizado el acceso por escrito remoto al equipo.
- **VSS o volumen shadow copies:** son copias de seguridad que el propio sistema operativo realiza a lo largo del tiempo de manera manual o automática y quedan ocultas en el sistema de archivos del usuario. Estas copias permiten a un investigador forense poder ver los cambios que se han producido en el equipo y qué ficheros existían anteriormente en el ordenador.



2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo macOS

Aunque el sistema operativo macOS no sea tan utilizado de manera habitual, como Windows, también es un sistema sumamente relevante a la hora de realizar un análisis forense. A continuación, se detallan algunos de los artefactos más relevantes del sistema macOS:

- **Eventos del sistema:** este fichero permite a los investigadores forenses poder seguir la pista de archivos que puede que ya no sigan en el sistema. Por ejemplo, comprobar si un fichero posee el valor de «renombrado» permitirá al investigador ver la trayectoria de los cambios que ha sufrido el archivo.
- **Archivos en cuarentena:** permite visualizar qué ficheros han sido puestos en cuarentena por el macOS Gatekeeper.
- **Archivos usados recientemente:** este artefacto recolecta información de todas las aplicaciones o archivos que han sido recientemente abiertos por el usuario, así como conocer qué archivos han sido abiertos por otras aplicaciones.



FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Linux

Por otro lado, en el sistema operativo Linux también podemos encontrar una serie de artefactos:

- **Cuentas de usuario:** un analista forense podría comprobar las cuentas de usuarios que han conseguido loguearse en el sistema.
- **SSH activity:** generalmente, en las empresas los sistemas Linux se suelen emplear como servidores. Normalmente, se utilizará una conexión SSH (o *Secure Shell*), por lo que comprobar los diferentes indicadores que muestra la conexión SSH sería muy relevante. La conexión SSH es un protocolo que permite el acceso remoto a un servidor a través de un canal seguro donde la información está cifrada. Los tres artefactos que formarían estos indicadores son:
 1. **SSH keys:** con el que podemos identificar cualquier llave tanto pública como privada utilizada en nuestro sistema.

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Linux

2. **SSH *known host*:** se trata de un listado de todos los *hosts* remotos conocidos por el equipo y que, previamente, han realizado una conexión con el sistema.
 3. **SSH *authorized keys*:** indica qué claves de SSH están autorizadas para iniciar sesión a la cuenta de usuario del sistema.
- **Tareas programadas:** en los servidores Linux muchas veces se programan tareas o estas se dejan en funcionamiento. El fichero de tareas programadas es un archivo muy valioso para los analistas forenses dado que les proporciona la información sobre las tareas que han estado funcionando en el equipo. Además, es importante tener en cuenta que muchos *malware* utilizan tareas programadas y *crontabs* para mantener persistencia en el equipo. Un *crontab* es un archivo de texto que guarda una lista con comandos que todavía se ejecutarán en un período de tiempo establecido por el usuario.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: artefactos: sistema operativo Linux

- **Logs del sistema:** casi todas las aplicaciones en Linux generan logs o registros por lo que la revisión del fichero syslog permite identificar cualquier acción inapropiada que se haya llevado a cabo en el equipo.
- **Papelera de reciclaje (*trash*):** este artefacto funciona de manera parecida a la papelera de reciclaje de los equipos macOS, ya que en él se buscan dos fuentes de datos: el fichero y cualquier metadato asociado a este. Un ejemplo sería la fecha en la que se eliminó el fichero.
- **Historial de Bash:** nos permite identificar si se ha estado utilizando la línea de comandos y qué comandos se han ejecutado en el equipo. Sin embargo, no se indica a qué hora se realizó cada ejecución, pero sí en qué orden fue llevada a cabo esta acción.



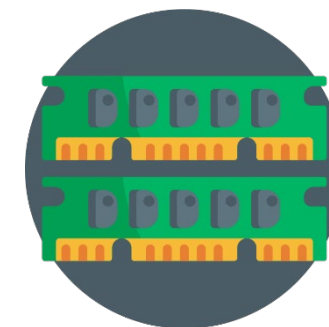
2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias

Una vez adquiridas las evidencias de los dispositivos o de los sistemas de la investigación se procederá al análisis de estas evidencias. En la fase de análisis de evidencias también se deberá de cumplir con la cadena de custodia y con las normas en cuanto al acceso restringido a las evidencias y el almacenamiento de las mismas.

Si bien el análisis suele ser estático, es decir, que sigue siempre el mismo procedimiento, existen dos casos excepcionales en los que el procedimiento puede variar:

- **Sistemas que no pueden ser clonados o que al apagarse el sistema se pierde la información:** en estos casos, se produce la extracción de evidencias «en vivo», así como del volcado de la memoria RAM, de los procesos en ejecución o de cualquier otro dato relevante.



2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias

- **Sistemas que han de ser ejecutados para su análisis:** como alternativa, se preparará un entorno de prueba a través de una máquina virtual para que simule un entorno real donde se lanzará el sistema de clonado para analizar el comportamiento de los sistemas. Cabe destacar que algunos programas, por ejemplo, algunos tipos de *malware*, si detectan que están siendo ejecutados en una máquina virtual, detienen su ejecución.



FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias

Durante esta fase se aplicarán técnicas científicas y analíticas sobre las evidencias obtenidas y los dispositivos clonados para determinar cuáles han sido las causas de lo sucedido y así obtener cualquier detalle relevante para la investigación. Algunas técnicas más utilizadas son:

- La búsqueda de cadenas de caracteres relacionadas con el caso de la investigación, relacionado con FEE mencionado anteriormente.
- La evaluación de las acciones específicas de los usuarios o de las aplicaciones durante el proceso.
- La comprobación de las actividades que han tenido lugar en el sistema.
- La búsqueda y recuperación de ficheros específicos.
- El análisis de la caché del navegador.
- La evaluación de los archivos descargados, creados o a los que se han accedido.
- La revisión de los eventos del sistema.
- El análisis de la localización de los equipos.

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de *logs*

Uno de los artefactos y herramientas más importantes a tener en cuenta a la hora de hacer un análisis forense son los *logs* o registros. Los *logs* son unas grabaciones secuenciales de la información del sistema, esto es, cuando se ejecuta una aplicación en el sistema, este guardará un *log* que indicará el momento de la ejecución de esa aplicación.

El análisis de los *logs* ayudará a la investigación forense en los siguientes ámbitos:

- Encontrar la vulnerabilidad que fue explotada para efectuar el ataque.
- Buscar las evidencias del ataque que se ha producido.
- Permitir la recuperación de los datos que pudieron ser perdidos tras el ataque.
- Seguir los pasos o el rastro que ha dejado el ciberdelincuente.

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de *logs*

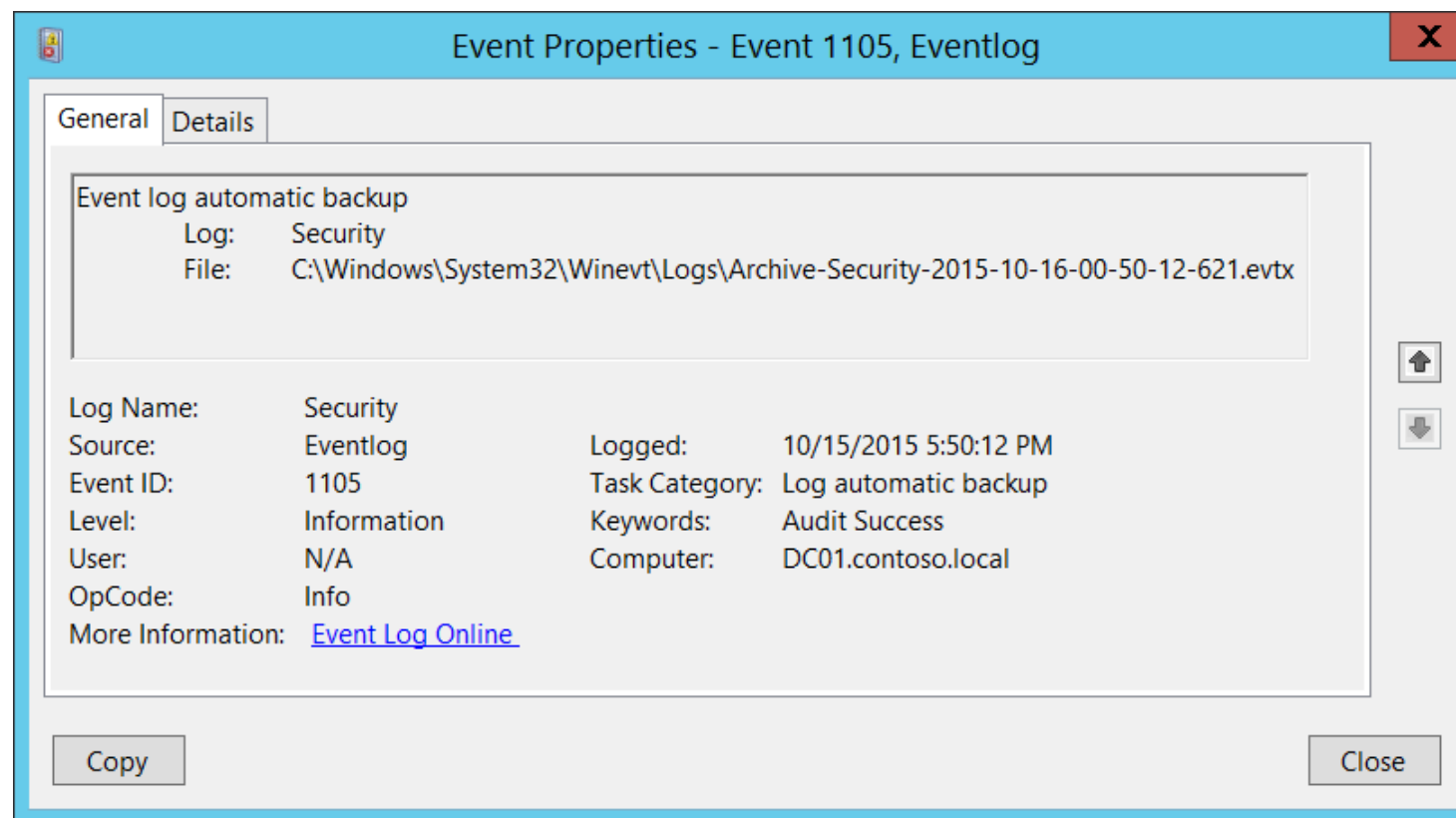
A la hora de realizar el análisis de los *logs* se deberán recoger los *logs* o registros que sean relevantes para la investigación que se esté realizando.

En el caso del sistema operativo Windows:

- **Logs de las aplicaciones:** por ejemplo, si se trata de una página web, el *log* podría contener el momento temporal en el que se visita la web, la duración de la sesión, la dirección IP, el sistema operativo utilizado, etc. La ruta es C:\Windows\System32\winevt\Logs\Application.evtx
- **Logs de herramientas de seguridad:** es decir, todos los *logs* producidos por el funcionamiento de alguna herramienta de seguridad, como un cortafuegos o *firewall*, un IDS, un IPS, etc. La ruta es C:\Windows\System32\winevt\Logs\Security.evtx
- **Logs del sistema:** incluyen mensajes de inicio, cambios en el sistema, cierres inesperados, errores, advertencias, etc. La ruta es C:\Windows\System32\winevt\Logs\System.evtx

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de *logs*



Fuente: *Ejemplo log de Windows*

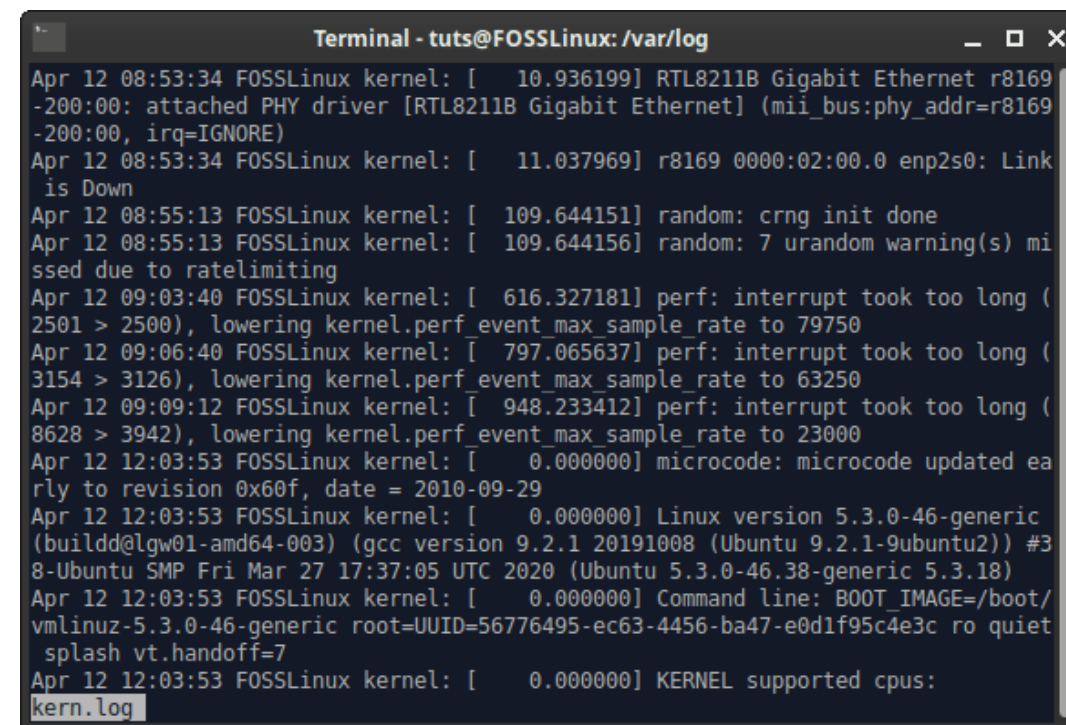
[Captura de pantalla] Extraído de: <https://docs.microsoft.com/>

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de *logs*

En el sistema operativo Linux podremos encontrar los *logs* en las siguientes direcciones:

- **Logs del sistema:** /var/log/messages
- **Logs de autenticación del sistema:** /var/log/auth.log
- **Logs del Kernel:** /var/log/kern.log
- **Logs de inicio del sistema:** /var/log/boot.log
- **Logs de inicio de sesión:** /var/log/utmp o /var/log/wtmp



```
Terminal - tuts@FOSSLinux: /var/log
Apr 12 08:53:34 FOSSLinux kernel: [ 10.936199] RTL8211B Gigabit Ethernet r8169
-200:00: attached PHY driver [RTL8211B Gigabit Ethernet] (miibus:phy_addr=r8169
-200:00, irq=IGNORE)
Apr 12 08:53:34 FOSSLinux kernel: [ 11.037969] r8169 0000:02:00.0 enp2s0: Link
is Down
Apr 12 08:55:13 FOSSLinux kernel: [ 109.644151] random: crng init done
Apr 12 08:55:13 FOSSLinux kernel: [ 109.644156] random: 7 urandom warning(s) mi
ssed due to ratelimiting
Apr 12 09:03:40 FOSSLinux kernel: [ 616.327181] perf: interrupt took too long (
2501 > 2500), lowering kernel.perf_event_max_sample_rate to 79750
Apr 12 09:06:40 FOSSLinux kernel: [ 797.065637] perf: interrupt took too long (
3154 > 3126), lowering kernel.perf_event_max_sample_rate to 63250
Apr 12 09:09:12 FOSSLinux kernel: [ 948.233412] perf: interrupt took too long (
8628 > 3942), lowering kernel.perf_event_max_sample_rate to 23000
Apr 12 12:03:53 FOSSLinux kernel: [ 0.000000] microcode: microcode updated ea
rly to revision 0x60f, date = 2010-09-29
Apr 12 12:03:53 FOSSLinux kernel: [ 0.000000] Linux version 5.3.0-46-generic
(bulld@lgw01-amd64-003) (gcc version 9.2.1 20191008 (Ubuntu 9.2.1-9ubuntu2)) #3
8-Ubuntu SMP Fri Mar 27 17:37:05 UTC 2020 (Ubuntu 5.3.0-46.38-generic 5.3.18)
Apr 12 12:03:53 FOSSLinux kernel: [ 0.000000] Command line: BOOT_IMAGE=/boot/
vmlinuz-5.3.0-46-generic root=UUID=56776495-ec63-4456-ba47-e0d1f95c4e3c ro quiet
splash vt.handoff=7
Apr 12 12:03:53 FOSSLinux kernel: [ 0.000000] KERNEL supported cpus:
kern.log
```

Fuente: *Ejemplo log de Linux*
[Captura de pantalla] Extraído de:
<https://hazlolinux.com>

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de *logs*

Otros *logs* relevantes que se pueden recolectar, dependiendo de la incidencia que se está analizando, son:

- **En el caso de un ataque a la Red**, se deberán recolectar los *logs* de todos los equipos de red que se encuentran en el camino del equipo del atacante y el *router* perimetral, es decir, el *router* ISP (*router* del proveedor de servicios de Internet).
- **Frente a un acceso no autorizado**, se guardarán todos los *logs* relacionados con este acceso, los *logs* del servidor, de aplicaciones, del *router*, del *switch*, del cortafuegos o firewall y de la base de datos.
- **Si se ha producido un ataque de un troyano o un virus**, los *logs* del evento, así como los del antivirus, también se deberán almacenar.

Dado que los *logs* son evidencias volátiles, se debe evitar realizar ciertas acciones que puedan perder información que pueda ser relevante para el caso, como reiniciar el equipo infectado antes de haber obtenido los *logs*, modificar el equipo infectado, antes de finalizar el análisis forense y, por último, realizar algún cambio de los *logs*, dado que esto podría destruir alguna prueba.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de memoria

El análisis de memoria consiste en volcar la memoria (también denominada *memory dump*) de un ordenador para su posterior análisis en busca de evidencias sobre el ataque que ha sufrido el dispositivo. Estas evidencias son volátiles, por ello, el *memory dump* o RAM *dump* se realizará sobre el equipo a investigar en primeras instancias de la investigación según se recoja el equipo y el análisis de memoria se suele realizar para investigar e identificar algunos tipos de ataques maliciosos que no suelen dejar rastro en el disco duro.

Una *memory dump* es una captura de la memoria de un ordenador. Este volcado puede contener información valiosa para realizar el análisis forense en los datos de la memoria RAM, ya que esta puede reportar información sobre qué fue lo que sucedió durante el ataque e información del sistema antes de que se produjera el incidente.

Independientemente de que los programas sean maliciosos o no, estos deben ser cargados en la memoria para poder ejecutar el volcado y, por ello, un *memory dump* podrá proporcionar información muy relevante para el caso.

2 FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: análisis de memoria

El análisis de memoria proporciona información muy valiosa que no se podría obtener de otra manera, ya que muchos tipos de *malware* que se instalan directamente en la memoria física del ordenador o en la memoria RAM no son detectados por algunas de las soluciones de seguridad enfocadas a la Red, como los antivirus o los cortafuegos o *firewalls*.

La información que podríamos obtener de un análisis de memoria sería sobre:

- Las conexiones de redes abiertas.
- Los comandos o procesos ejecutados recientemente.
- Las credenciales de acceso.
- Los fragmentos de código inyectado.
- Las claves encriptadas.
- El historial de navegación de Internet.



FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: inicio de la investigación

En la fase de inicio de la investigación forense digital, se deben tener en cuenta los siguientes factores:

- Bloqueadores de escritura *hardware* y *software*: sirven para evitar que las evidencias puedan ser modificadas por alguna equivocación.
- Métodos de obtención de evidencias forenses: deberán ser acordes con los estándares y, en todo momento, verificables.
- Las imágenes forenses: deberán ser copiadas por herramientas HW y/o SW que sean capaces de copiarlas fielmente.
- La integridad de los datos de las evidencias forenses debe mantenerse en todo momento.
- El equipo de creación de imágenes: deberá ser debidamente preparado y limpiado de cualquier dato de anteriores copias para que no se produzca ningún incidente en la posterior copia de las evidencias.

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: examinación

En la fase de examinación de la investigación forense digital, de deben tener en cuenta las siguientes consideraciones:

- Antes de comenzar con el examen de las imágenes forenses, los examinadores deberán revisar toda la documentación aportada por el cliente para verificar el procedimiento que van a realizar y que se van a cumplir todos los requisitos legales.
- Además, se deberá tener en cuenta la prioridad que tiene el cliente para que se realice la investigación forense, los diferentes tipos de examen forense que se van a llevar a cabo en las evidencias para su priorización y cuáles son las evidencias que más probabilidades tienen de proporcionar más datos para la investigación.
- El análisis forense nunca se deberá realizar sobre la evidencia original. A ser posible, se llevará a cabo siempre que exista una copia adicional de la misma.
- El proceso que tendrá lugar durante la investigación deberá ser acordado entre el equipo de examinadores y el cliente.

FASES DEL ANÁLISIS FORENSE

Fase 3: análisis de las evidencias: creación de la línea temporal

Para la correcta realización de un análisis forense se debe tener en cuenta cuál es el objetivo último de la investigación, es decir, saber qué ha sucedido en los dispositivos afectados con una incidencia y presentar una narrativa de los eventos ocurridos de forma coherente, creíble y basada en evidencias que lo demuestren.

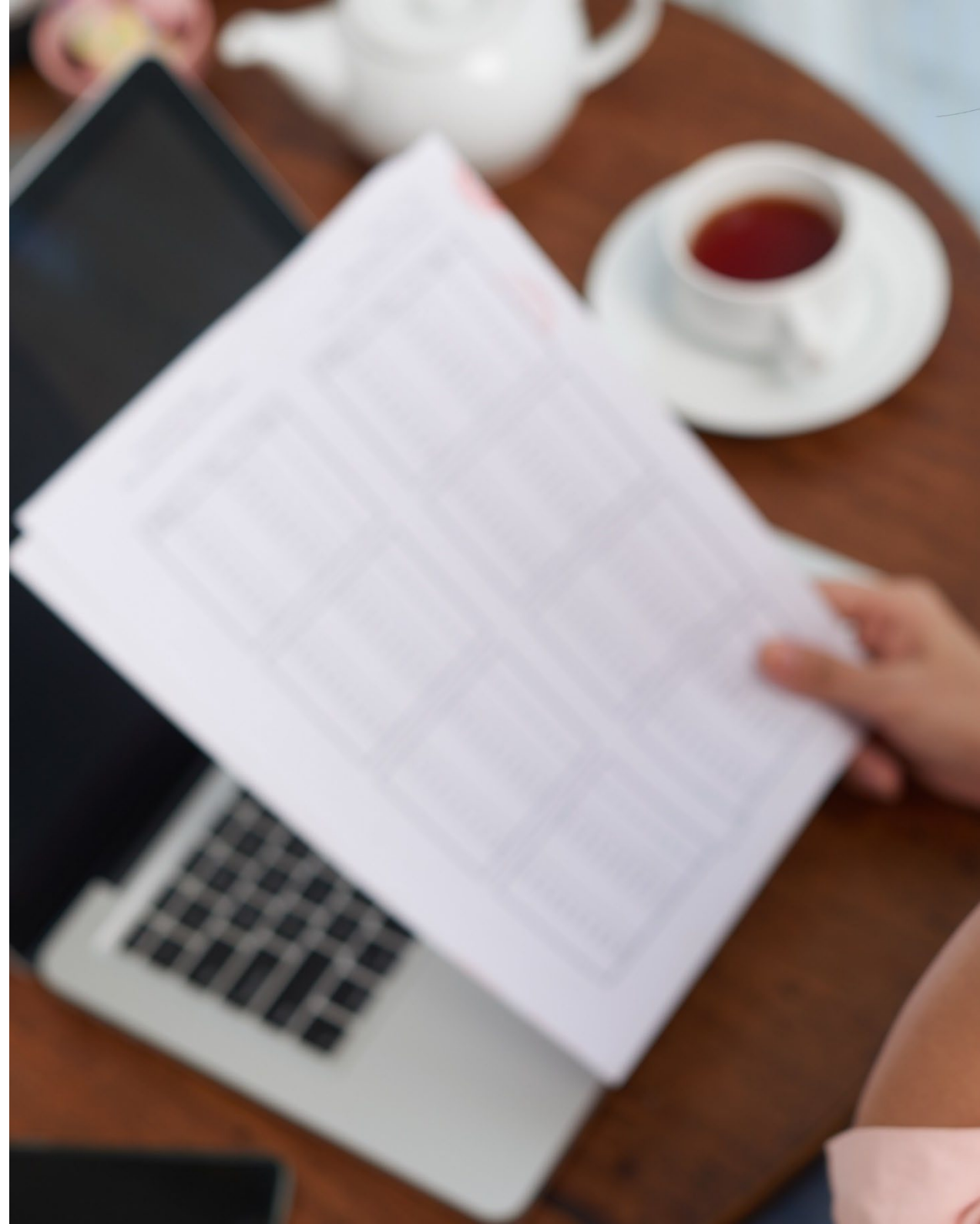
Para ello, se deberá crear una **línea temporal** de todos los hechos acontecidos en los dispositivos que se estén investigando para crear una narrativa que verifique que las conclusiones a las que se está llegando, gracias a las investigaciones de las evidencias. Esto ayudará a la hora de crear el informe final, dado que una investigación puede tardar meses en concluirse, por lo que poseer una narrativa adecuada y metódica hace que las explicaciones que se den resulten más coherentes, manteniendo así una línea temporal de los hechos.

2 FASES DEL ANÁLISIS FORENSE

Fase continua: documentación

Esta última fase es continua al resto de fases que hemos visto hasta ahora y es esencial que comience desde la primera fase de identificación de la evidencia y planteamiento del caso.

Debe recoger todas las acciones que se han realizado paso a paso, lo que permitirá disponer de un informe completo, claro y ordenado de todo lo sucedido y las actividades que se han llevado a cabo.



FASES DEL ANÁLISIS FORENSE

Fase continua: documentación

En la fase de documentación de la investigación forense digital, de deben tener en cuenta las siguientes medidas:

- Para la revisión de la documentación, la organización a la que los examinadores pertenecen deberá contar con políticas que establezcan cómo se ha de proceder para realizar la revisión de una investigación, así como con un procedimiento adecuado en los casos en los que una investigación no consiga aprobar dicha revisión.
- La documentación del análisis forense deberá contar con:
 - La copia de las autorizaciones legales para hacer la investigación.
 - El estado de la cadena de custodia.
 - La anotación del número de evidencias que se van a examinar y una descripción de las mismas.
 - La información sobre el estado de la de las evidencias al ser recibidas por el examinador.
 - Todas las comunicaciones que se hayan realizado durante la incidencia.

FASES DEL ANÁLISIS FORENSE

Fase continua: documentación

- Los documentos del análisis deberán aportar una línea temporal de todas las acciones que se hayan realizado durante la examinación, así como las capturas de dichas acciones para permitir que otro investigador forense pueda verificar que la examinación sí se ha hecho correctamente o continuarla si fuese necesario. Además, todos los informes de la examinación deberán presentar los requisitos de la organización a la que pertenezcan los examinadores y los informes que envíen al cliente deberán responder a sus necesidades, siendo estos redactados de forma concisa para transmitir la información de manera transparente.



FASES DEL ANÁLISIS FORENSE

Fase continua: documentación: presentación del informe final

Tras concluir con la fase de análisis de las evidencias y definir una línea temporal de lo ocurrido, se procederá a crear los informes que reflejarán todos los detalles de la investigación, las evidencias oportunas y cualquier detalle legítimo que verifique los resultados obtenidos. El informe deberá contener una serie de aspectos, entre los que se pueden destacar:

- **Asunto:** hace referencia al objeto del informe.
- **Análisis:** se indican las evidencias que se han recogido, así como las pruebas que se van a realizar sobre las mismas y la finalidad que se pretende conseguir con su realización. Además, se recoge la documentación de las pruebas realizadas y su seguimiento paso a paso, junto con la cadena de custodia de cada una de las evidencias.
- **Conclusiones:** hace referencia a la proposición final del informe en base al análisis realizado previamente.

2 FASES DEL ANÁLISIS FORENSE

Fase continua: documentación: presentación del informe final

Existen dos tipos de informes finales:

- **El informe detallado**, que contiene todas las actividades y tareas que se han llevado a cabo en la investigación, el método y procedimientos seguidos para obtener la información, así como los resultados obtenidos de las evidencias encontradas.
- **El informe ejecutivo** presenta un resumen de alto nivel de los resultados obtenidos en el análisis forense y se distribuye entre los responsables de la investigación. Este informe se complementa con el informe detallado con el objetivo de validar los resultados por parte de los ejecutivos si fuera conveniente.



FASES DEL ANÁLISIS FORENSE

Fase continua: documentación: presentación del informe final

En el caso de que fuera preciso un dictamen judicial, las guías más utilizadas son:

- **UNE 197001:2019** [\[8\]](#) de criterios generales para la elaboración de informes y dictámenes periciales.
- **UNE 71506:2013** [\[9\]](#) de las tecnologías de la información (TI). Se trata de una metodología específica muy utilizada en el análisis forense de las evidencias electrónicas. En el anexo A de esta guía se proponen los campos mínimos que debe cumplir un dictamen judicial, como el asunto, las evidencias o muestras recibidas, la resolución o los estudios efectuados sobre estas, la situación final de las evidencias o muestras, las conclusiones finales y, por último, el anexo del informe.
- **ISO/IEC 27037:2016** [\[10\]](#) de directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas.

ANÁLISIS FORENSE DE *MALWARE*

3 ANÁLISIS FORENSE DE MALWARE

Análisis de *malware*

Todos los procedimientos de un análisis forense serán distintos dependiendo de qué tipo de incidente se haya producido. Aunque todos los análisis forenses tienen un proceso similar, haremos una introducción al análisis de *malware* dado que contiene algunas variantes importantes.

Aunque ambas investigaciones, forense y de *malware*, comparten muchas características relativas a las técnicas y herramientas que se utilizan, hay que tener en cuenta que un análisis de *malware* no es un análisis forense. Las principales diferencias entre ambos son:

Análisis forense

- Determinación de hechos acontecidos.
- Búsqueda de evidencias.
- Cadena de custodia.
- Evidencias con valor judicial.

Análisis de *malware*

- Análisis de archivos maliciosos.
- Búsqueda de los efectos de la infección.
- Generación de soluciones y medidas preventivas.

3 ANÁLISIS FORENSE DE MALWARE

Introducción

Un análisis de *malware* sucede cuando se ha detectado un posible archivo malicioso en un equipo, es decir, hace referencia al conjunto de técnicas que se deben realizar sobre el archivo infectado con el objetivo de obtener la información necesaria para identificar el tipo de *malware* que ha infectado el equipo y eliminar todo rastro de este, además de prevenir futuras infecciones.

Dada la naturaleza cambiante de los *malware*, se hace necesario que el investigador cuente con unos conocimientos técnicos, tanto de redes, programación y arquitectura avanzados, así como poseer las herramientas adecuadas para realizar la tarea de manera efectiva.

Este tipo de análisis es especialmente importante en las fases de contención, erradicación y recuperación de los sistemas que han podido verse infectados. Dado que cada día se encuentran cientos de miles de nuevas versiones de *malware*, tanto variantes de *malware* ya existentes como nuevas versiones, los analistas deben de estar al día de cualquier nueva versión que exista, así como nuevas vulnerabilidades se vayan encontrando.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de análisis de *malware*

Existen dos formas de realizar el análisis de *malware*: el análisis estático y el análisis dinámico.

- **Análisis estático:** consiste en analizar un posible archivo malicioso sin la ejecución de este, fijándose en el código del archivo. De esta forma, se puede validar si, ciertamente, se trata de un archivo malicioso, proporcionando así información sobre su funcionamiento. Este tipo de análisis es fácil, pero suele ser inútil ante *malware* sofisticado y, como ya se ha mencionado, se trata de un análisis superficial que no profundiza en el comportamiento del *malware* en sí.
- **Análisis dinámico:** a diferencia del anterior, el análisis dinámico se centra en la ejecución del archivo malicioso y en observar su comportamiento, es decir, cuáles son las acciones que realiza dentro del sistema pudiendo, a través de su comportamiento, discernir de qué clase de *malware* se trata. Este tipo de análisis puede revelar nombres de dominios y direcciones IP con las que se comunique el *malware*, claves de registro que pueden haber sido modificadas y la localización de más ficheros infectados.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de análisis de *malware*

El análisis dinámico se debe realizar en un entorno controlado, que puede ser en un equipo de pruebas aislado de la red corporativa o dentro de un programa especial que simule ser un entorno real. A este tipo de programas se les conoce como *sandboxes* y pueden ser máquinas virtuales o programas específicos para análisis de *malware*. Cabe destacar que algunos *malware* avanzados impiden su análisis en una *sandbox*, deteniendo su ejecución si detectan que están siendo ejecutados en este tipo de entornos controlados.

Análisis de *malware*: entorno *sandbox*

Como acabamos de mencionar, un entorno *sandbox* es esencial para el análisis de *malware*, dado que permite probar el archivo infectado en un entorno cerrado donde no existe riesgo de infección. Así, se puede crear un entorno propio para el testeo de *malware*, pero, a su vez, existen muchas soluciones fáciles de implementar en este entorno, como Cuckoo, Drakvuf, Sandboxie y VMRay.

3 ANÁLISIS FORENSE DE MALWARE

Análisis de *malware*: entorno *sandbox*

Estos entornos permitirán observar con facilidad el comportamiento del fichero sospechoso de ser malicioso, así como modificar la forma en la que el sistema interactuará con él, simulando un comportamiento humano durante el proceso para engañar a los *malware* más sofisticados o utilizando la herramienta TOR en vez de la conexión habitual a Internet, ya que en su última versión (TOR 7.0) se dispone de modo *sandbox*.

Algunas de las evidencias más destacadas que un entorno *sandbox* puede revelar son:

- Si se han modificado las claves de registro: suele ser indicativo de que se está ejecutando un *malware* en el sistema, dado que se suelen modificar las claves de registro para ganar persistencia.
- Creación de nuevos procesos y uso de CPU.
- Comunicación con IP externas o dominios: un *malware* puede establecer una conexión remota con el atacante o descargar más componentes del *malware* para continuar con la infección.

ANÁLISIS FORENSE DE MALWARE

Análisis de *malware*: entorno *sandbox*

- Si se genera alguna ventana oculta: suele indicar actividad maliciosa, dado que indicaría que se están realizando acciones en segundo plano.
- Si se crean nuevas *Yara rules*: estas reglas se encargan de identificar *malware* a través de la estructura binaria del ejecutable.
- Dependiendo del *sandbox* que se esté utilizando, este contrastará el *hash* del fichero con diferentes repositorios de virus para comprobar si se encuentra entre ellos.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

Un analista forense deberá tener en cuenta los diferentes tipos de *malware* que se puede encontrar durante un procedimiento de investigación forense, ya que pueden aportar información acerca de cuáles fueron las causas de la incidencia y aportar nuevas evidencias al caso. Para identificar la ejecución de un *malware* en un equipo durante el proceso de una investigación no existe un proceso exacto que nos diga cómo estos actúan, dado que cada *malware* puede actuar de maneras completamente diferentes. Por ello, será necesario realizar análisis de firmas, análisis de comportamiento o análisis de memoria para poder detectar claramente un *malware*. Aun así, dada la naturaleza de los *malware*, estos realizarán varias acciones que nos facilitarán su identificación. A continuación, se detallan los tipos de *malware* que existen y sus principales variantes:



3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Adware:** se trata de un *malware* que se instala sin el consentimiento del usuario y muestra publicidad no solicitada, intrusiva, enlaces a sitios que pueden ser maliciosos e incluso anuncios que pueden estar potencialmente infectados. Para poder identificar la ejecución de un *adware* nos fijaremos en los programas que se han ejecutado en el sistema por si observamos alguno que resulte extraño, ya que el *adware* suele ser un programa bastante visible. Si se ha infectado un navegador, esto puede haber sucedido a través de los *plugins* que tiene este navegador. Nos tendremos que fijar en estos para identificarlo o también nos podremos fijar en los programas que se inician según se enciende PC, ya que un *adware* suele intentar crear persistencia en el inicio de sesión del sistema. Existen numerosos tipos de *adware*, algunos de los más conocidos son:

1. **OpenCandy:** se trata de un *software* que se instala en equipos Windows y que muestra al usuario diferentes tipos de *software* y aplicaciones promocionales dependiendo de la información que recolecte tras el escaneo que haga del equipo.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*



¿Sabías qué?

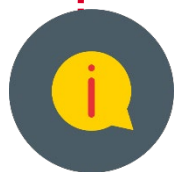
En 2019 una vulnerabilidad llamada SimBad afectó a 206 aplicaciones, provocando así una campaña masiva de *adware* móvil. [\[11\]](#)

2. **FasterXP**: es un *software* que se habilita al arrancar el sistema para impedir que se cierre y muestra una interfaz gráfica con anuncios al usuario de manera periódica.
3. **InstallCore**: se trata de un programa que se distribuye junto a un *software* legítimo y causa la instalación de *software* no deseado, generando así ventanas emergentes o *pop-ups* e inyectando anuncios en la navegación y actividad del usuario.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Spyware:** hace referencia a un *malware* que se especializa en la obtención y robo de información personal del usuario sin su consentimiento. Al igual que el *adware*, el *spyware* puede mostrar publicidad al usuario, pero, generalmente, se centra en la recopilación de información del equipo. Para identificarlo lo haremos de la misma forma que un *adware*, nos fijaremos en los procesos del equipo y si alguno de estos procesos es sospechoso. También nos podremos fijar en algún programa sospechoso al inicio de sesión del equipo. Otro lugar donde se podrá buscar información es en la carpeta temporal y, si detectamos un archivo sospechoso, deberemos analizarlo para determinar que se trata de un *malware*.



¿Sabías qué?

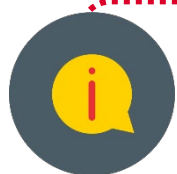
Unos ciberdelincuentes utilizaron un *spyware* denominado Torisma, que estaba encubierto en ofertas de trabajo dirigidas a los sectores aeroespacial y defensa. [\[12\]](#)

ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

Existen distintos *spyware*, los más destacados son:

1. **CoolWebSearch (CWS)**: este *malware* infectaba Internet Explorer, cambiando la página de inicio del buscador y recopilando información acerca de las búsquedas que realizaba el usuario y de su información personal.
2. **Transponder (VX2)**: se trata de un *spyware* distribuido con algunas aplicaciones gratuitas que registra los datos que el usuario introduce en el navegador para recopilar información.
3. **Scranos**: hace referencia a un *malware* distribuido con un *software* no legítimo, el cual es capaz de extraer credenciales de un gran número de aplicaciones del sistema.



¿Sabías qué?

Bizarro es un nuevo troyano que ha atacado a más de 70 bancos en todo el mundo. [\[13\]](#)

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Troyano:** este tipo de *malware* se especializa en obtener el acceso a un equipo para crear una puerta trasera que esté siempre disponible para llevar a cabo acciones maliciosas cuando el atacante lo desee, como realizar otros tipos de ataque *malware*, robar información sensible, realizar modificaciones del sistema, etc. Para poder identificar la ejecución de un troyano en el sistema tendremos que tener en cuenta primero que, dependiendo del tipo de troyano, este se podrá comportar de manera diferente. Para poder identificar un troyano nos tendremos que fijar en varios factores:
 1. Al igual que el *adware* y *spyware*, suele intentar crear persistencia al inicio de sesión del equipo.
 2. Puede intentar detener el *firewall* del equipo para poder ejecutarse.
 3. Intenta modificar claves de registro para crear persistencia en el equipo.
 4. Intenta modificar el explorador del equipo para ocultar ficheros o extensiones.
 5. Realiza conexiones maliciosas.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- Algunos de los troyanos más conocidos son:
 1. **Zeus/Zbot**: se trata de un troyano que, tras infectar un equipo, realiza ataques *Man-in-the-Middle* para interceptar credenciales y datos sensibles.
 2. **Anubis**: hace referencia a un tipo de *malware* troyano que está enfocado en robar y suplantar entidades bancarias en dispositivos móviles Android. Se distribuye mediante SMS fraudulentos y aplicaciones no confiables.



3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Rootkit:** es un tipo de *malware* que se instala en el equipo a bajo nivel y se oculta de tal manera que el sistema operativo no es capaz de detectarlo. Esto permite a los atacantes burlar la seguridad del equipo y actuar de manera efectiva como usuario administrador. Los *rootkits* se instalan con varios objetivos, dependiendo de las herramientas que dispongan, como robar información, instalar un *malware*, ocultar de programas, etc. Dada la naturaleza de los *rootkits*, a la hora de identificarlos no se podrán detectar en procesos particulares del sistema, pero podremos intentar buscar los procesos de Windows por actividad sospechosa, como en la SSDT, tabla de descripción de servicios del sistema, que muchos *rootkits* secuestran para enmascarar su actividad o buscar en el equipo por particiones ocultas dado que algunos *rootkits* las crean.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

La mejor forma para identificarlos se hará mediante el análisis completo del equipo durante la investigación:

1. Análisis de firmas, el *software* de análisis comparar la firma de *malware* ya identificado con la firma de los archivos en el equipo por si identifica alguna coincidencia.
2. Análisis de comportamiento del equipo para identificar comportamientos extraños.
3. Análisis de un *dump* de memoria del equipo.

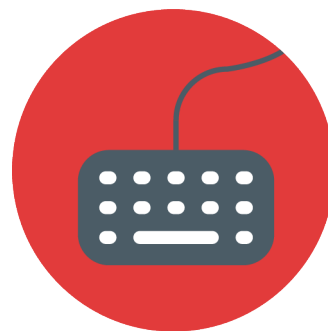
Algunos de los *rootkits* más conocidos son:

1. **TorPig**: se oculta en los sectores de arranque del equipo que infecte y tiene como objetivo robar las credenciales del usuario, así como sus datos bancarios.
2. **LoJax**: se trata de un *rootkit* que afecta a la interfaz de *Firmware Extensible Unificad* (UEFI). Este aprovecha funcionalidades de comunicación incluidas por defecto en algunos sistemas para ganar persistencia tras formatearlos.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Keylogger:** este *malware* captura todo lo que el usuario escriba, de manera que así puede interceptar actividades, nombres de usuario, contraseñas, etc. Para poder identificar un *keylogger*, al igual que con otros *malware* ya mencionados nos fijaremos en los procesos que se están ejecutando en el sistema, por si observásemos alguno sospechoso. También podremos fijarnos en la carpeta *temporal* existe algún fichero sospechoso y, como en otros casos, podremos observar si existe algún programa sospechoso activado en el inicio de sesión del equipo.

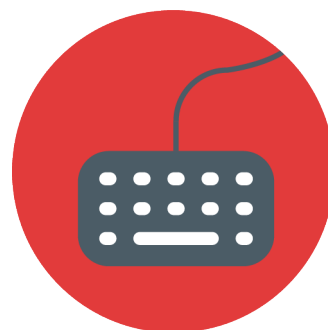


3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

Existen distintos tipos de *keyloggers*, los más destacados son:

1. **Zusy**: está enfocado al robo de credenciales bancarias. Su alcance está muy limitado, por lo que no puede reproducir los datos enviados.
2. **Azorult**: este *keylogger* es capaz de capturar la interacción que hace el usuario con el equipo y, además, es capaz de robar credenciales guardadas y cacheadas en el sistema y en sus aplicaciones.
3. **Keyloggers físicos**: estos son conectados a la salida de del teclado y permiten capturar toda la información sin que el sistema pueda detectarlo.



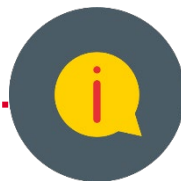
3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

- **Botnet:** se trata de un *malware* que permite el control remoto de un equipo por parte de un atacante. La *botnet* suele ser utilizada para realizar ataques de denegación de servicio (DoS). Para saber identificar si un equipo es parte de una *botnet* nos deberemos de fijar en las conexiones de Internet que esta ha realizado para poder identificar si establece comunicación con alguna IP maliciosa. Las *botnets* más conocidas son:
 1. **Conficker:** es una de las *botnets* más conocidas, ya que pudo infectar a más de 15 millones de equipos en grupos de más de 4 millones por infección.
 2. **Kraken:** esta *botnet* ha infectado al 10 % de las principales empresas internacionales.
 3. **Mariposa:** en este caso, se trata de dos *botnets* que comparten dependencias y que llegaron a infectar a más de 10 millones de equipos. Los ciberdelincuentes mantenían un registro de los equipos que realizaban pagos, lo que permitió la desarticulación de este equipo.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*



¿Sabías qué?

La *botnet* Meris, a través de 250.000 dispositivos, ha conseguido batir el récord del mayor ataque DDoS dos veces. [\[15\]](#)



Oficina
de Seguridad
del Internauta

INCIBE dispone a través de la OSI de un servicio *antibonet* [\[14\]](#).

3 ANÁLISIS FORENSE DE MALWARE

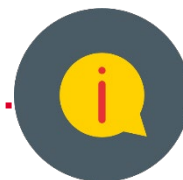
Tipos de *malware*

- **Ransomware:** este tipo de *malware* se especializa en bloquear el acceso al contenido de un dispositivo, en ocasiones cifrando los datos y ficheros del mismo. Una vez ejecutado en el sistema, el *ransomware* cifrará todos los ficheros en el equipo y pedirá un rescate económico para la recuperación de los archivos cifrados. Se caracteriza por cifrar los datos con un cifrado robusto que no puede ser roto con ataques de fuerza bruta y los pagos se suelen pedir a través de medios no trazables, como la criptomoneda Bitcoin. Identificar la ejecución de un *ransomware* en un equipo es algo simple, dado que los discos del ordenador se encontrarán cifrados y no se podrá acceder al equipo o no se podrá acceder al contenido del dispositivo. Existen distintos tipos de *ransomware*, veamos algunos de ellos:
 1. **Petya:** apareció por primera vez en 2016 y afecta a los sistemas Microsoft Windows encriptando el archivo de sistema del disco duro e impidiendo al equipo iniciarse con normalidad.

3 ANÁLISIS FORENSE DE MALWARE

Tipos de *malware*

2. **TeslaCrypt:** ya no está operativo. Este *ransomware* se centraba en cifrar los datos relacionados con videojuegos. A medida que evolucionó, fue capaz de cifrar otros ficheros y pedía al usuario un pago por devolverle todos sus datos.



¿Sabías qué?

Estos son los 5 grupos de *ransomware* más activos de los últimos años. [\[16\]](#)

3 ANÁLISIS FORENSE DE MALWARE

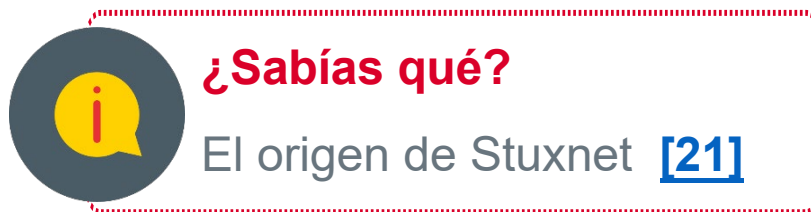
Tipos de *malware*

- **Virus:** los virus son la familia de *malware* más antigua y su nombre se suele emplear para englobar la gran mayoría de amenazas genéricas, es decir, el resto de las familias de *malware*. El objetivo de los virus suele ser atacar al sistema o producir inestabilidad en el equipo que infecten. Los gusanos son un tipo de virus que, en vez de centrarse en replicarse en el máximo número de ficheros posible y dañar el sistema del equipo que infecte, afectan a toda la red en la que se encuentra el dispositivo. Para identificar un virus nos deberemos fijar en las acciones que se han realizado en la máquina, si se han modificado archivos eliminados o si algún archivo tiene un tamaño anormal que nos daría información sobre un virus que intenta sobrecargar la capacidad del disco duro o un proceso que esté consumiendo una cantidad excesiva de la memoria del equipo. Los tipos de virus más destacados a lo largo de los años han sido:

3 ANÁLISIS FORENSE DE MALWARE

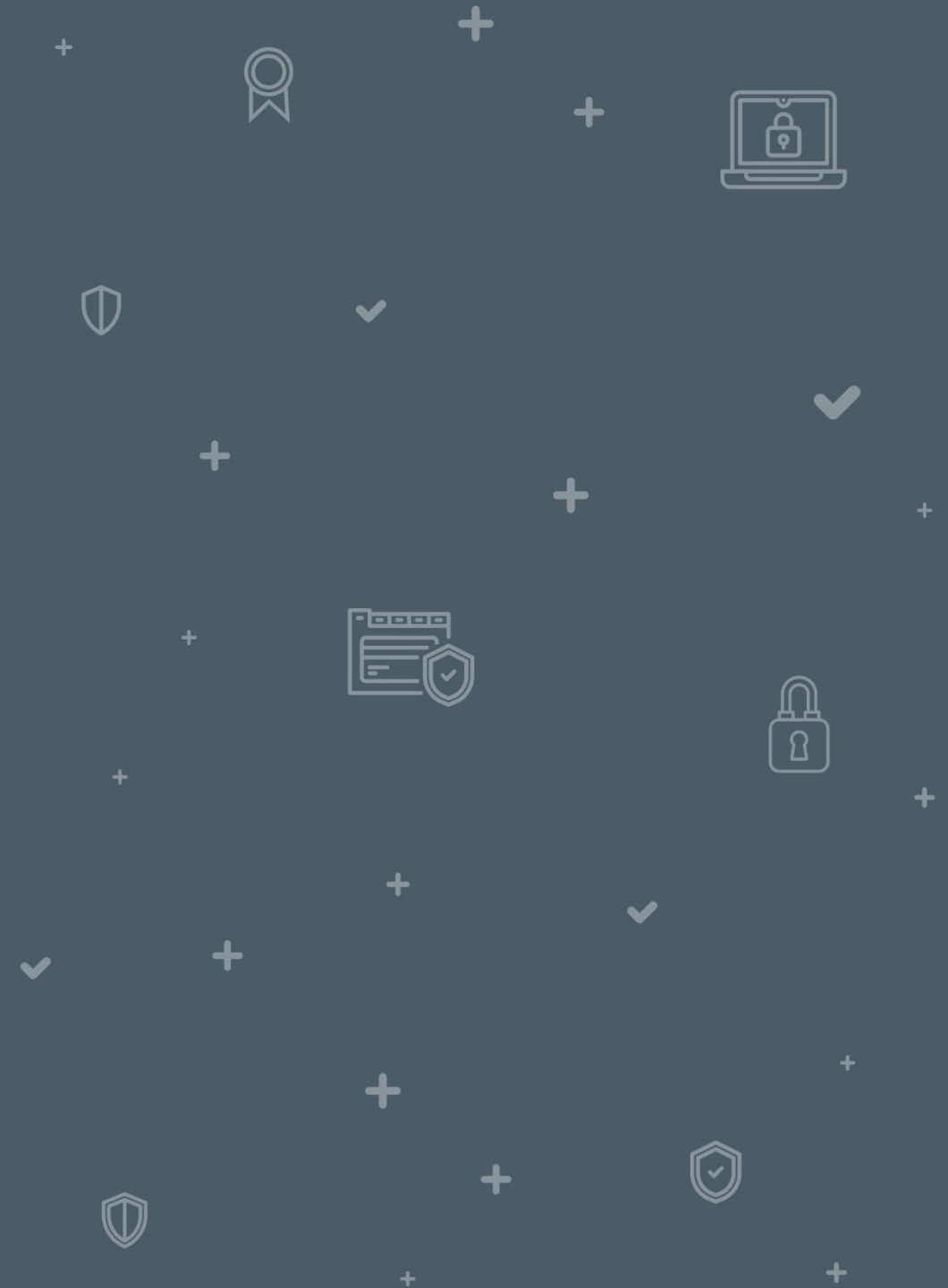
Tipos de *malware*

1. **Mydoom** [\[17\]](#): este gusano se propagaba por correo electrónico. En 2004 se llegaron a detectar más de 100.000 instancias por hora, una doceava parte del correo total de la época.
2. **Sasser** [\[18\]](#): su objetivo era explotar vulnerabilidades en el *Local Service Authority Subsystem Service* (LSASS) para su distribución y causar así el fallo del equipo.
3. **Stuxnet** [\[19\]](#): este virus, creado para la ciberguerra, infecta no solo equipos sino también dispositivos PLC industriales. En 2020 se utilizó, principalmente, para atacar centrales nucleares iraníes.
4. **Triton** [\[20\]](#): está enfocado a sistemas industriales y es capaz de desactivar sistemas de instrumentalización de las familias de dispositivos Triconex.



4

ANÁLISIS ESPECIALES



ANÁLISIS ESPECIALES

Análisis de dispositivos IoT

Un aspecto de la investigación forense que también debemos tener en cuenta es el análisis de dispositivos IoT, dado que cada vez se está extendiendo más la utilización de esta tecnología.

Como vimos en la primera unidad, IoT (*Internet of Things* o Internet de las Cosas) hace referencia a una tecnología que interconecta diferentes dispositivos a través de la Red, los cuales disponen de sensores para captar información que luego será procesada para realizar diferentes acciones. Por ejemplo, los asistentes virtuales son dispositivos IoT que poseen sensores que captan la voz de las personas y un *software* que interpreta lo que se dice para realizar las acciones que se le pidan.

Dado que cada vez son más los dispositivos que poseen esta tecnología, esto implica que son más las incidencias de seguridad que están surgiendo.

ANÁLISIS ESPECIALES

Análisis de dispositivos IoT

La característica principal de los dispositivos IoT que supone un grave un problema a la hora de realizar una investigación forense es su interconectividad. Dado que estos dispositivos se encuentran conectados a una red o poseen repositorios en la nube, todos ellos pueden verse comprometidos por un incidente. Por lo tanto, el alcance de la investigación aumenta.

En este caso, una investigación forense deberá investigar toda aquella posible infección dentro de la red a la que estén conectados los dispositivos IoT. Por ello, un analista forense deberá tener en cuenta varios factores antes de comenzar la investigación:

- La variedad de los dispositivos IoT que se encuentran interconectados.
- Los datos almacenados en los diferentes dispositivos.
- Los datos pueden ser modificados o borrados en toda la red desde un único dispositivo.
- Los datos almacenados en la nube que pueden encontrarse en diferentes zonas geográficas.

4 ANÁLISIS ESPECIALES

Análisis de dispositivos IoT

Además, se deberán aumentar las fuentes de las que provienen las evidencias para la investigación forense de los dispositivos IoT. Estas fuentes de evidencias podrán ser categorizadas en tres grupos diferentes:

- **Dispositivos inteligentes y sensores:** se deberá recoger como evidencia el dispositivo que ha generado la incidencia, además de todos los dispositivos que están conectando a su misma red. Por ejemplo, los asistentes de voz virtuales o los relojes inteligentes.
- **Software y hardware:** es decir, todos aquellos dispositivos que provean conexión con Internet a estos dispositivos, como podrían ser los ordenadores y los cortafuegos o *firewalls*.
- **Recursos externos:** se trata de fuentes de evidencias que pueden no estar en la misma red que los dispositivos investigados, como las redes sociales o almacenamiento de ciertos archivos en la nube.

Una vez recuperadas todas las evidencias posibles, se seguirá la metodología de un análisis forense convencional, pero, como ya hemos mencionado, siempre teniendo en cuenta que el alcance de la investigación en los dispositivos IoT puede ser mucho mayor.

ANÁLISIS ESPECIALES

Análisis en la nube

Como hemos mencionado en el apartado anterior, la prevalencia cada vez mayor del uso de la nube para almacenar información y su conexión constante a todos estos dispositivos, hace que sea relevante mencionar cómo sería el procedimiento de una investigación forense del entorno de la nube.

Lo primero que tendrá que identificar el analista forense es a qué tipo de entorno en la nube nos estamos enfrentando, dado que, a medida que aumenta el nivel de abstracción en el cual el cliente posee menos control sobre el *hardware*, se hará cada vez más complicada la obtención de datos.

El investigador forense deberá ser capaz de diferenciar entre las diversas arquitecturas de servicios alojados en la nube:

- **SaaS (del inglés *Software as a Service*):** se trata de un modelo de distribución en el que el proveedor externo de la nube aloja el *software* de la organización y el cliente de la misma puede acceder a este a través de una interfaz web.

4 ANÁLISIS ESPECIALES

Análisis en la nube

- **PasS (del inglés *Platform as a Service*):** esta plataforma actúa como un tipo de tecnología en la nube en la que el propietario del servicio solo es responsable de los datos y las aplicaciones que se crean en dicha plataforma, pero no de la infraestructura, ya que el servidor es gestionado por un tercero.
- **IaaS (del inglés *Infrastructure as a Service*):** hace referencia a un modelo en el que el cliente contrata la infraestructura de *hardware* a un proveedor a cambio de una cuota al mes.

Una vez identificado el tipo de infraestructura a la que se enfrenta el analista forense, este deberá proceder a la obtención de evidencias. Si se tiene acceso a la infraestructura, debería intentar obtener un *snapshot*, esto es, una imagen de una máquina virtual de los dispositivos que se quieran investigar. Si no, se deberá pedir al proveedor del servicio todos los datos e intentar validar su integridad de la mejor manera posible.

Una alternativa sería clonar los *snapshots* que se han generado de los entornos de la nube que se está investigando en una máquina virtual local para analizarlos de forma similar a como se haría en una investigación forense convencional.

4 ANÁLISIS ESPECIALES

Análisis en la nube

Estos son algunos de los inconvenientes a los que se enfrenta un analista forense a la hora de realizar un análisis en la nube:

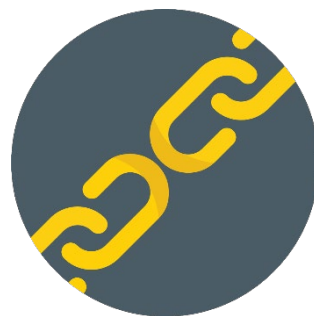
- **La jurisdicción de la investigación:** dado que los datos que pueden resultar útiles para la investigación pueden estar alojados en diferentes países, su acceso puede conllevar problemas dependiendo de las leyes de cada país.
- **Las evidencias han sido modificadas por un tercero:** porque el acceso a la nube puede llevarse a cabo a través de más de un único dispositivo. Además, en los entornos PaaS y SaaS los clientes dependen de los proveedores para acceder a los *logs* o registros, dado que ellos no tienen un control directo sobre la infraestructura.



4 ANÁLISIS ESPECIALES

Análisis en la nube

- **Mantener la cadena de custodia:** resultará complicado, ya que cuando se realiza un análisis forense tradicional, el propio equipo de seguridad es el que se encarga de recopilar las evidencias, mientras que, en los casos de análisis en la nube, esta recopilación suele depender del proveedor para entregar las evidencias. Por ello, tal vez no se tenga constancia de quién es la persona que ha recopilado las evidencias ni de si lo ha hecho con la metodología adecuada, lo cual podría romper la cadena de custodia haciendo que esas evidencias sean irrelevantes e inválidas.
- Es más complicado **recuperar datos borrados** dada la volatilidad de los mismos y la gran cantidad de datos que se pueden encontrar en uno de estos servicios.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: introducción

Además del análisis forense convencional, debemos tener en cuenta otros dispositivos no comunes o diferentes en los que no se lleva a cabo el mismo tipo de análisis.

Cada vez más se pueden encontrar otros dispositivos que nos aportan más información relevante en los diferentes escenarios de una investigación forense digital, por lo que tendremos que ser capaces de analizarlos y extraer toda la información o los datos que sean relevantes para el caso.



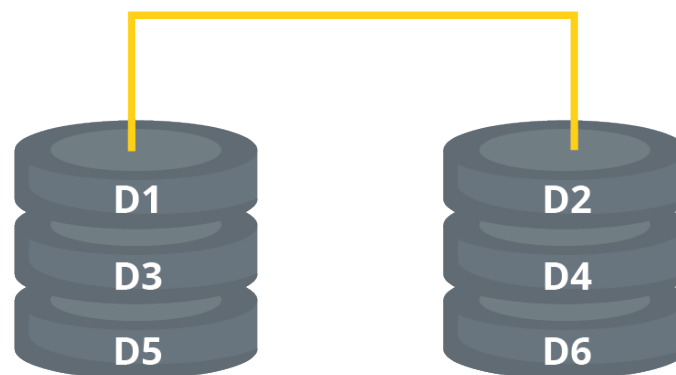
4 ANÁLISIS ESPECIALES

Dispositivos no comunes: RAID

RAID (*Redundant Array of independent Disks*) hace referencia al aprovechamiento de un conjunto de discos de almacenamiento independientes y configurados de tal forma que se pueda obtener mejor rendimiento y/o disponibilidad e integridad de los datos almacenados.

Existen diferentes niveles de RAID:

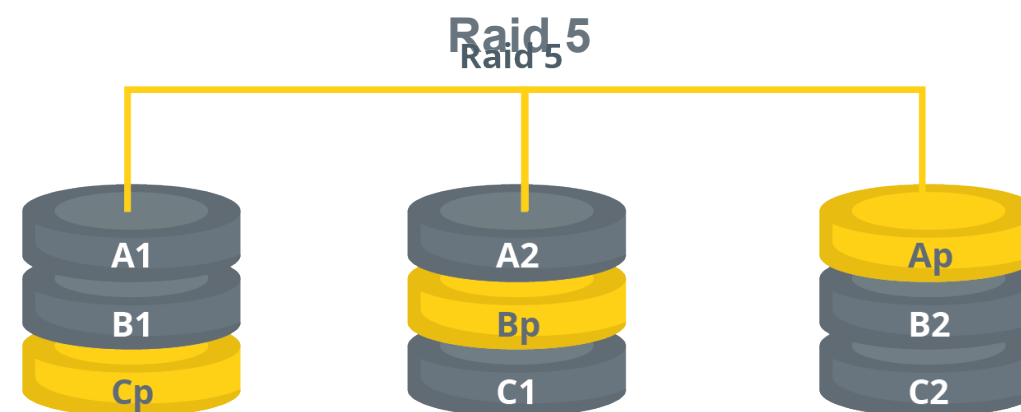
- **RAID 0:** este divide los datos entre los discos duros disponibles, balanceando así la carga del sistema. En este nivel no se realiza ningún tipo de copia de seguridad, por lo que perder el disco duro causaría la pérdida de todos los datos o evidencias.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: RAID

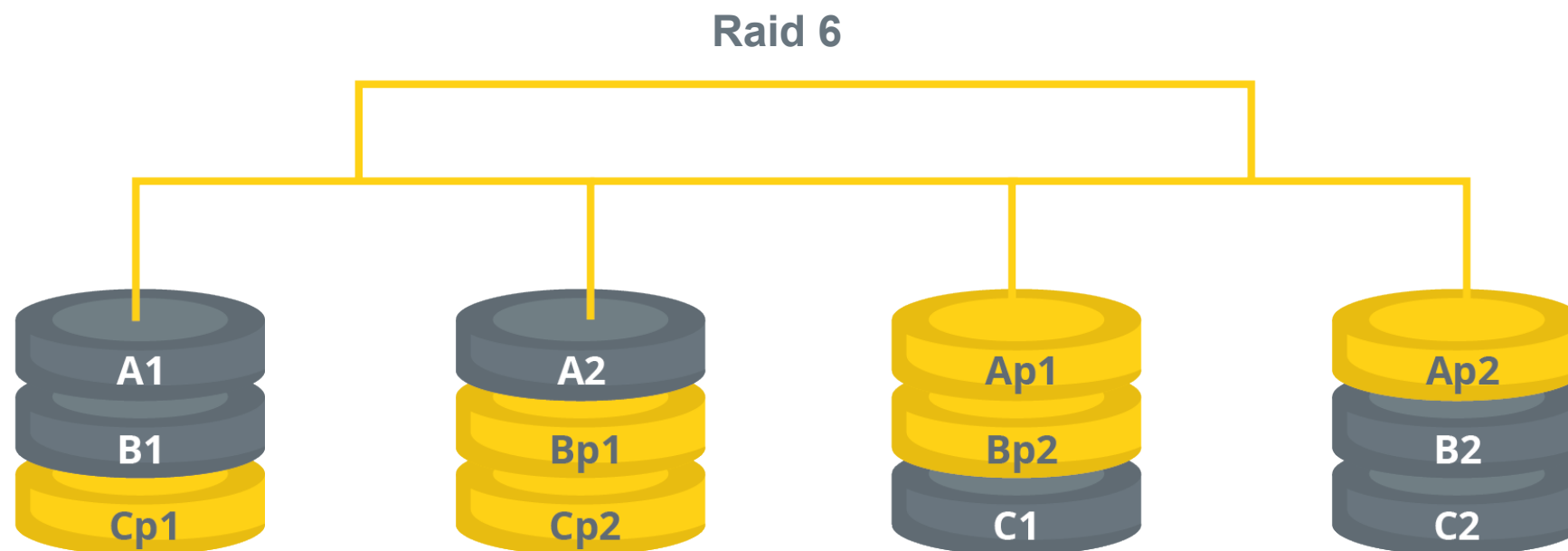
- **RAID 1 o *Data-mirroring*:** realiza una copia exacta de los datos en dos o más discos duros, lo que permitirá que, si un disco duro falla, la información siga disponible en el resto.
- **RAID 5:** almacena la información entre varios discos duros junto con la información de recuperación, por lo que si uno de los discos duros falla se podrían recuperar los datos gracias a la copia alojada en el resto.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: RAID

- **RAID 6:** es un sistema similar al RAID 5, pero añade más discos duros de paridad, pudiendo así recuperar la información incluso en el caso de que fallen 2 discos duros o más.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: RAID

La división de datos que se consigue con el sistema de RAID provoca que el clonado de este tipo de infraestructuras sea mucho más complejo para realizar un análisis forense. Si bien se podrían clonar todos los discos duros directamente, también sería necesario disponer de una infraestructura igual a la original y con la misma configuración del controlador.

Teniendo en cuenta los inconvenientes que proveen este tipo de dispositivos no comunes para la realización de un análisis forense, será necesario la reconstrucción de los discos para su clonado y recuperar así la información.

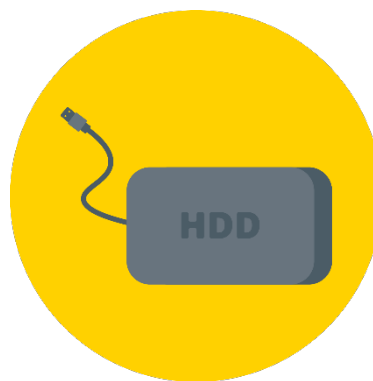


4 ANÁLISIS ESPECIALES

Dispositivos no comunes: RAID

Dependiendo del tipo de RAID que se utilice, se deberán hacer las siguientes indicaciones:

- RAID 0: se puede realizar un clonado físico de los discos duros, pero como los datos se encuentran repartidos entre varios discos duros, puede ser que surjan problemas para calcular el *hash*.
- RAID 1: dado que los datos se encuentran redundados, solo sería necesario realizar el clonado de uno de los discos duros, ya que el *hash* será idéntico en todos ellos.
- En los casos de RAID 5 y RAID 6 no se podrá realizar el clonado de estos formatos.



ANÁLISIS ESPECIALES

Dispositivos no comunes: servidores virtualizados

Un **servidor virtual o virtualizado** es una simulación de un servidor físico en un entorno virtual. Recordemos que los servidores son sistemas informáticos que almacenan, procesan y suministran información a los usuarios de una manera rápida y eficaz. Estos sistemas también permiten acceder a varios usuarios a diferentes recursos e información y, además, compartirlos.

La **virtualización de servidores** consiste en disponer de un servidor físico donde podremos ejecutar varios servidores virtuales al mismo tiempo.

La gran ventaja del análisis de servidores virtuales es que disponemos de ellos en todo momento. Para realizar la copia de un servidor virtual deberemos extraer la imagen del servidor virtual y copiarlo y pegarlo en nuestro disco y, además, calcular el *hash* de la imagen y de la copia realizada para valorar si se ha hecho correctamente la copia del servidor.

ANÁLISIS ESPECIALES

Dispositivos no comunes: discos cifrados

Hoy en día existen muchos portátiles y ordenadores que están cifrados o utilizan métodos de cifrado de ficheros para proteger la confidencialidad de la información y los datos que están almacenados en ellos.

En el sistema operativo Windows la herramienta BitLocker es la medida de cifrado más común al ser Windows el sistema original. Sin embargo, también existen otros tipos de herramientas alternativas, como VeraCrypt, PGP y Ubuntu Full-disk Encryption.

El clonado de estos discos duros se puede realizar de la misma manera que en el caso de los discos duros no cifrados. No obstante, no se podrá acceder directamente a los datos que se encuentren en su interior, por lo que para obtenerlos se tendrá que solicitar al propietario o responsable la clave de acceso al disco, disponer de una orden judicial que obligue a proporcionar esta clave o realizar un ataque de fuerza bruta para obtenerla.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: discos cifrados

Para poder detectar si se están utilizando discos cifrados, se pueden llevar a cabo las siguientes técnicas:

- *Encrypted Disc Detector* o EDD: este permite identificar discos cifrados ocultos en sistemas y otros medios de almacenamiento.

```
EDD.exe > "VolumenesEncriptados-%date:~6,4%%date:~3,2%%date:~0,2%-  
%time:~0,2%%time:~3,2%.txt"
```

- Carpetas mapeadas:

```
net use > "UnidadesMapeadas-%date:~6,4%%date:~3,2%%date:~0,2%-  
%time:~0,2%%time:~3,2%.txt"
```

- Carpetas compartidas:

```
net share > "CarpetasCompartidas-%date:~6,4%%date:~3,2%%date:~0,2%-  
%time:~0,2%%time:~3,2%.txt"
```

4 ANÁLISIS ESPECIALES

Dispositivos no comunes: TomTom

Para los dispositivos que posean antenas de geolocalización y/o radio, como es el caso de los navegadores TomTom, es necesario asegurar que se hace uso de una jaula de Faraday o de que se lleva a cabo alguna de las medidas de desconexión del dispositivo de la Red, para evitar así que se pueda modificar la configuración del mismo o de los datos de la geolocalización.

En estos dispositivos existen otros *softwares especializados* para poder realizar un análisis de forma más automática o en mayor volumen, como la herramienta TomTology2.



Ilustrativo de ejemplo.
Fuente: *TomTom GO 630 Tarjetas de memoria y accesorios* [Captura de pantalla] Extraído de:
<https://www.offtek.es/>

4 ANÁLISIS ESPECIALES

Dispositivos no comunes: TomTom

En este caso, los pasos a seguir serían los siguientes:

1. Aislar el dispositivo para evitar que se produzca alguna modificación en este.
2. Conectar el dispositivo GPS al equipo de análisis.
3. Instalar los *drivers* del dispositivo, si es necesario.
4. Realizar una copia de seguridad del disco duro del dispositivo con las herramientas y formatos que deseemos (.dd, .dc3dd, etc.).
5. Analizar el dispositivo con los diferentes tipos de herramientas *software* que hemos visto en la unidad: Autopsy, FTK Imager, Volatility, etc.



4 ANÁLISIS ESPECIALES

Dispositivos no comunes: TomTom

Algunos de los archivos más relevantes y frecuentes que se pueden encontrar dentro de los dispositivos TomTom son:

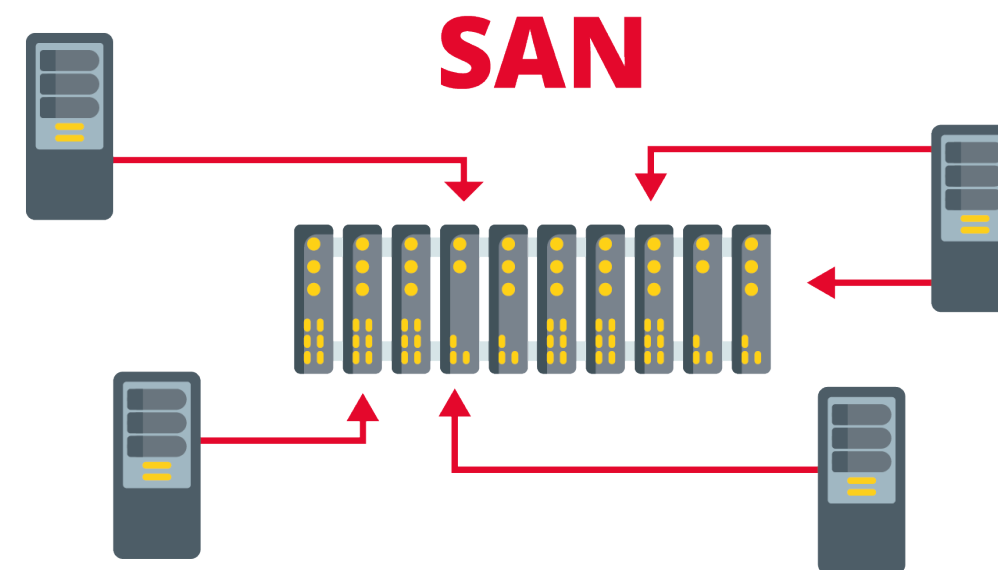
- «CurrentMap.dat»: se podrá observar el último mapa que fue cargado dentro de la última sesión.
- «ttgo.if/ttnavigator.bif»: se podrán encontrar los datos de configuración del usuario.
- «gprssettings.dat»: nos podrá mostrar los detalles de la configuración de Red, en el caso de que el dispositivo cuente con una tarjeta móvil.
- «mapsettings.cfg»: se podrán conocer los detalles de las ubicaciones recientes que se hayan visitado.
- «EngineRecents»: nos mostrará las diferentes localizaciones visitadas recientemente, como lugares y puntos de interés o particulares en el mapa del dispositivo.
- «LastKnownTrueGpsPosX/PosY»: almacena la última posición que haya cargado en el GPS del TomTom.

4 ANÁLISIS ESPECIALES

Dispositivos no comunes: SAN

Otro tipo de dispositivos no comunes son los denominados SAN (en inglés, *Storage Area Network*). Se trata de una red de servidores de almacenamiento interconectados de manera local que permiten el acceso a la información de los diferentes servidores y ordenadores de la organización.

Los dispositivos SAN se caracterizan por permitir el acceso, a través de los ordenadores de la organización, a la información almacenada en los SAN como si fuesen discos duros locales que están conectados al ordenador. A estos discos duros se les denomina LUN (del inglés *Logical Unit Number*) y podrían estar compuestos de uno o más discos duros.



ANÁLISIS ESPECIALES

Dispositivos no comunes: SAN

La gran cantidad de datos que se manejan en un dispositivo SAN dificulta la recolección de evidencias para una investigación forense digital. En el mejor de los casos, si los datos relevantes para la investigación se encuentran en un solo sistema, se podrá obtener únicamente la información del LUN asignado a ese sistema sin tener que analizar el resto del SAN. Aun así, la información que se extraiga podrá ser muy pesada para los equipos de almacenamiento forense.

Para poder hacer frente a este problema se han creado diferentes alternativas o soluciones. Algunas de ellas son:

- **Dispositivos que dispongan de múltiples RAID** y, a su vez, con varios terabytes de capacidad de almacenamiento.
- **Sistemas que permitan la expansión de los medios** a los que va destinada la información que se va a almacenar en ellos durante la fase de adquisición de evidencias.

4 ANÁLISIS ESPECIALES

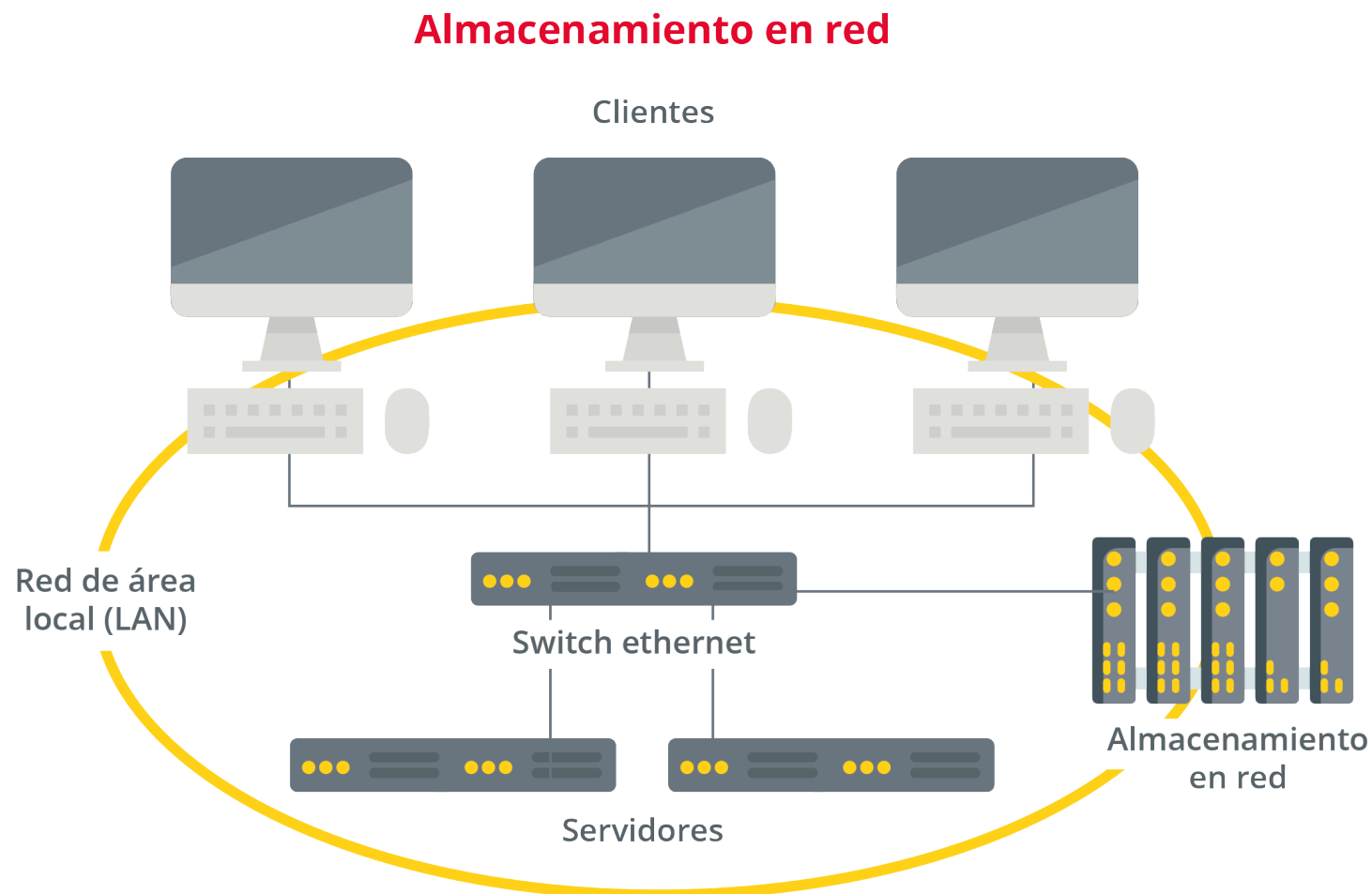
Dispositivos no comunes: NAS

Un sistema NAS (del inglés *Network-Attached Storage*) es un dispositivo de almacenamiento conectado a una red que permite almacenar y recuperar los datos en un punto centralizado para los usuarios autorizados y los clientes. Los dispositivos NAS son expansibles y flexibles, lo que implica que, si es necesario aumentar la capacidad de almacenamiento del dispositivo, podrá realizarse sin ningún problema.

Dado que estos dispositivos de almacenamiento de datos son muy simples y funcionan con muy pocos servicios y protocolos, esto dificultará la obtención de una imagen del dispositivo. Por ello, se recomienda la obtención de los datos almacenados en el NAS a través de algún equipo conectado a este. En caso de no ser posible, sería necesario desmontar el NAS y crear una imagen de cada *drive* uno por uno.

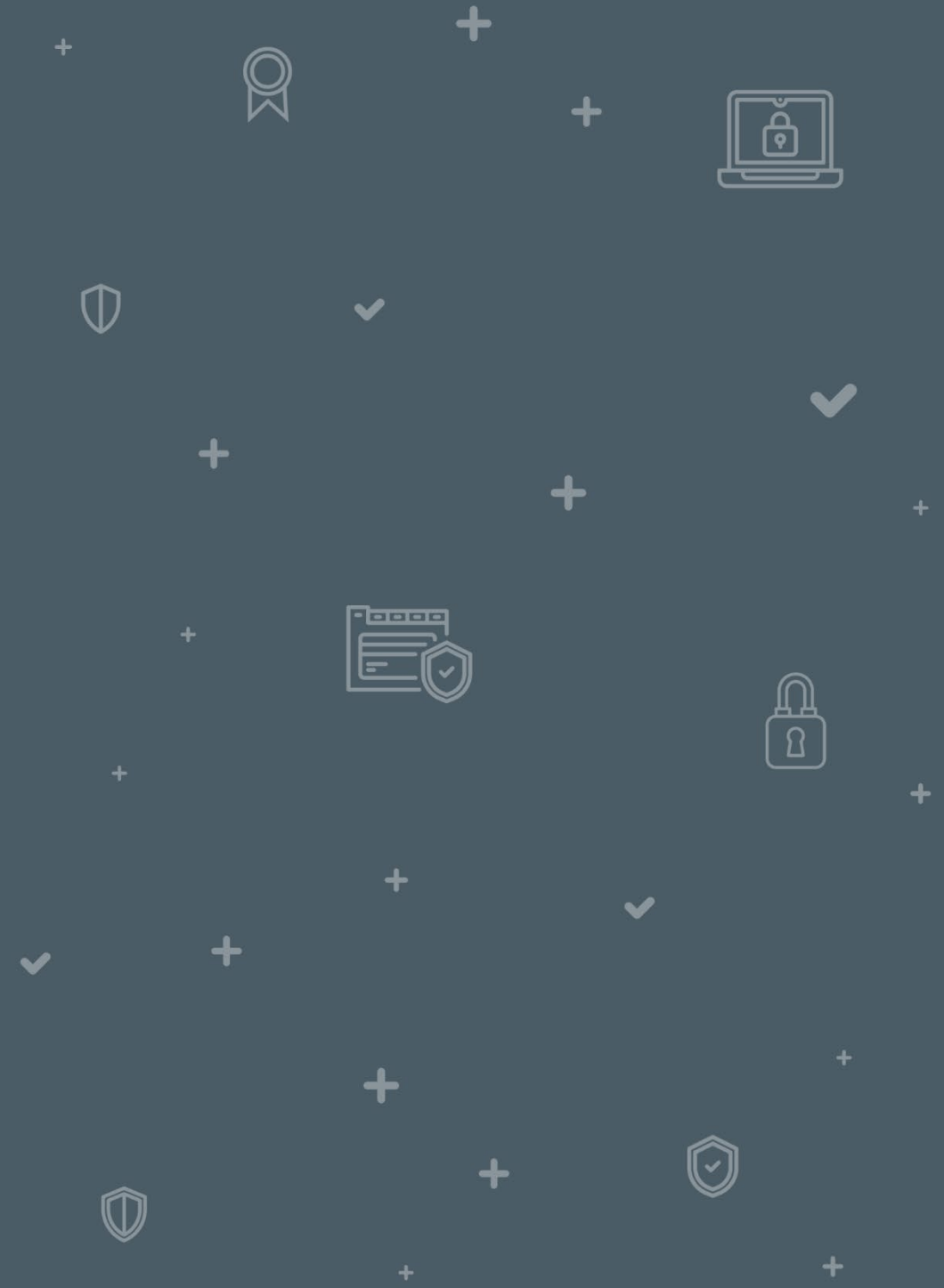
4 ANÁLISIS ESPECIALES

Dispositivos no comunes: NAS



5

METODOLOGÍA FORENSE



METODOLOGÍA FORENSE

Introducción a la normativa en el ámbito forense

Existen diferentes normativas y certificaciones que acreditan y validan los diferentes derechos y obligaciones que deben tener los investigadores forenses durante el trascurso de una investigación.

Algunas de las normativas y certificaciones a tener en cuenta son:

- **UNE 197001:2019** [\[22\]](#): establece los criterios generales para la elaboración de informes y dictámenes periciales.
- **UNE 71506:2013** [\[23\]](#) de las tecnologías de la información (TI): establece una metodología específica para el análisis forense de las evidencias electrónicas.
- **RFC 3227** [\[24\]](#): *Guidelines for Evidence Collection and Archiving*.
- **EC-Council (CHFI)** [\[25\]](#).

METODOLOGÍA FORENSE

UNE 197001:2019

La normativa UNE 197001:2019 engloba los criterios generales para la elaboración de informes y dictámenes periciales. Busca establecer los requisitos formales que se deben tener a la hora de crear un informe o un dictamen pericial. Al cumplir esta norma se ofrece seguridad, calidad y garantía procesal teniendo en cuenta el creciente número de actuaciones periciales profesionales.

Los capítulos principales de esta normativa son:

- Capítulo 4: Requisitos generales.
- Capítulo 5: Identificación.
- Capítulo 6: Declaración de tachas.
- Capítulo 7: Juramento o promesa.
- Capítulo 9: Cuerpo del informe o dictamen.

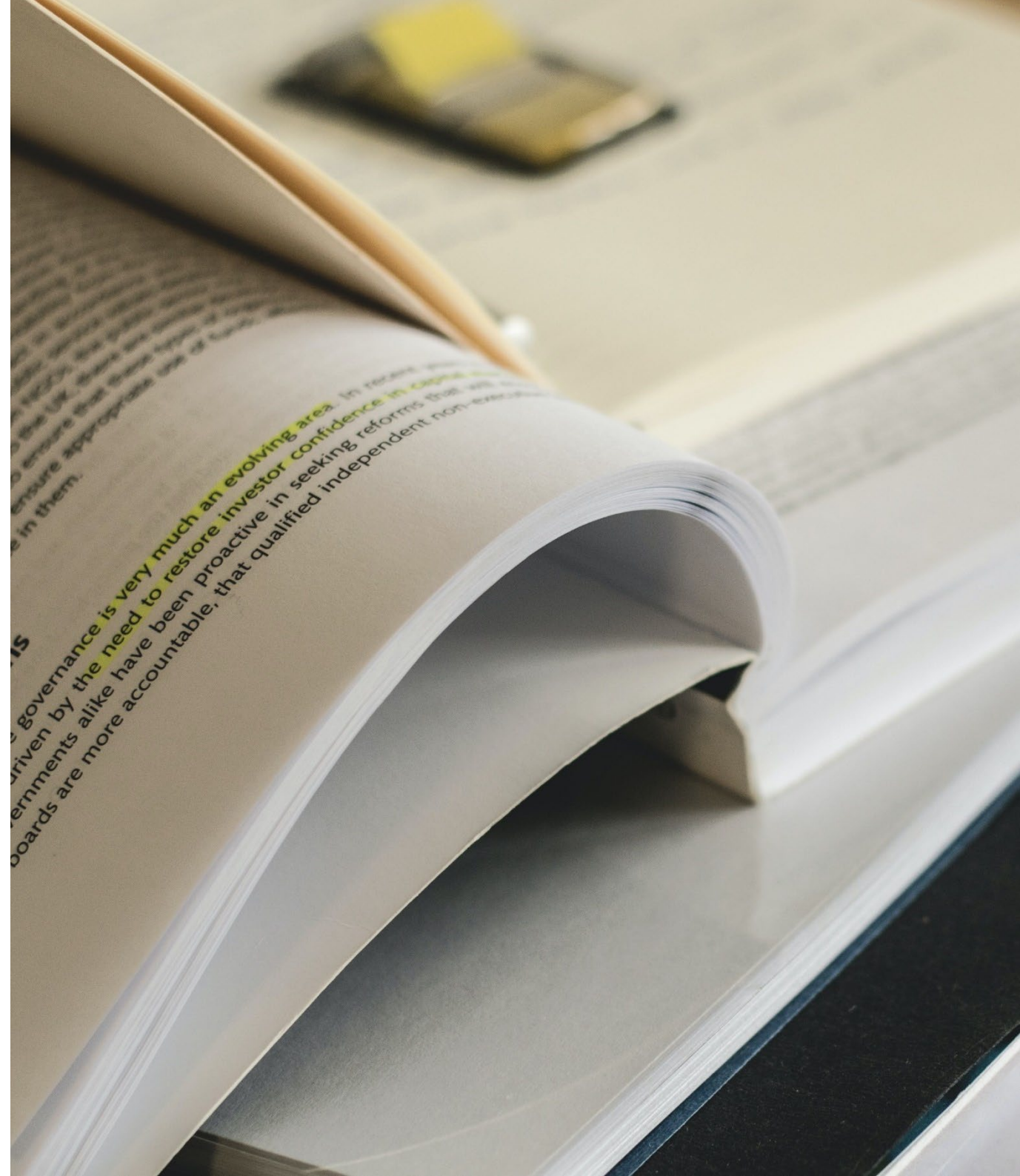
El informe o dictamen debe de disponer de un título único que permita su fácil identificación, así como un índice de paginación que ayude a localizar los apartados específicos.

5 METODOLOGÍA FORENSE

UNE 197001:2019

Además, en el informe o dictamen deberán indicarse:

- El nombre de los organismos a los que va dirigido el documento.
- El número de expediente, si aplicase.
- Los datos del perito encargado.
- Los datos del solicitante.
- Los datos relativos al emplazamiento geográfico.
- La fecha de emisión.



METODOLOGÍA FORENSE

UNE 197001:2019

Por otro lado, también se deberá establecer una estructura del documento compuesta por:

- El objetivo.
- El alcance.
- Los antecedentes.
- Las consideraciones preliminares.
- El documento de referencia.
- La terminología y referencias.
- El análisis realizado.
- Las conclusiones.
- Los anexos.

El documento deberá poseer una paginación transparente que muestre tanto el número de cada página como el total de páginas, evitando así que se pierdan hojas o que se incluya un contenido no autorizado o falsificado. Por otro lado, también deberá contener una declaración de tachas y un juramento o promesa que declare que se está diciendo la verdad.

METODOLOGÍA FORENSE

UNE 71506:2013

La UNE 71506:2013 ha sido elaborada por el Comité Técnico de Normalización de Aenor y engloba los criterios generales para la elaboración de los análisis forenses de las evidencias electrónicas, dando cabida a todos aquellos otros procesos que conforman el sistema de gestión de evidencias informáticas:

- Responder a las infracciones legales e incidentes informáticos que se produzcan en la empresa.
- Ayudar a la obtención de evidencias informáticas de manera fiable y atribuir correctamente los hechos, pudiendo entrever si estos son de origen malicioso o no.
- Ubicar y determinar de forma correcta los instrumentos, acciones, fines y otros parámetros para identificar conductas maliciosas.
- Se puede aplicar a cualquier organización y profesionales del ámbito forense y está dirigida especialmente a equipos de respuesta ante incidentes de seguridad, así como al personal técnico que trabaje en laboratorios o entornos de análisis forense de las evidencias electrónicas.

METODOLOGÍA FORENSE

UNE 71506:2013

Los capítulos principales de esta normativa son:

- Capítulo 6: Preservación de evidencias. Consiste en mantener la validez y la confiabilidad de las evidencias originales.
- Capítulo 7: Adquisición de evidencias. Se realiza el clonado de los datos originales.
- Capítulo 8: Documentación. Consiste en recopilar toda la documentación del procedimiento completo, desde el inicio hasta la entrega del mismo.
- Capítulo 9: Análisis. Se llevan a cabo los procesos y tareas realizadas durante el análisis para averiguar la causa de la incidencia y el motivo de la investigación.
- Capítulo 10: Presentación de los resultados. Se realiza el informe pericial con la información obtenida durante toda la investigación.

METODOLOGÍA FORENSE

UNE 71506:2013

Esta normativa se divide en diferentes fases:

1. **Preservación:** consiste en mantener la validez y la confiabilidad de las evidencias originales.
2. **Adquisición:** se realiza el clonado de los datos originales.
3. **Documentación:** consiste en recopilar toda la documentación del procedimiento completo, desde el inicio hasta la entrega del mismo.
4. **Análisis:** se llevan a cabo los procesos y tareas realizadas durante el análisis para averiguar la causa de la incidencia y el motivo de la investigación.
5. **Presentación:** se realiza el informe pericial con la información obtenida durante toda la investigación.

METODOLOGÍA FORENSE

RFC 3227

La guía RFC 3227 es un documento de alto nivel generado para la recolección y archivado de datos relativos a intrusiones. Este documento refleja, desde un punto de vista teórico, el proceso de actuación y pautas a seguir para realizar el análisis forense. Además, describe las mejores prácticas para determinar la volatilidad de los datos, decidir y desarrollar la recolección de estos y determinar cómo almacenarlos y documentarlos.

Esta guía se encuentra estructurada en diferentes categorías:

- Principios durante la recolección de evidencias: estos son, orden de volatilidad, errores a evitar consideraciones de privacidad y legales.
- Proceso de recolección: trata cuestiones de transparencia y pasos a seguir durante el análisis forense.
- Procedimiento de almacenamiento: hace referencia a la cadena de custodia y dónde se van a almacenar las evidencias.
- Herramientas necesarias: indica los pasos a seguir para la selección de las herramientas en el proceso de recolección de evidencias.

5 METODOLOGÍA FORENSE

RFC 3227

Uno de los puntos más importantes de la guía RFC 3227 es el énfasis dado al orden de volatilidad, que indica que se debe empezar la recolección de evidencias priorizando aquellas más volátiles.

Durante la recogida de estas evidencias, algunas de ellas van a suponer la utilización de herramientas que pueden afectar al estado de la máquina, por lo que antes de extraer estas pruebas, sería necesario hacer una copia de seguridad del equipo por si la manipulación de una prueba tuviese lugar. Así, la evidencia original siempre quedará intacta y la cadena de custodia no se romperá.

Las evidencias que se podrán extraer según el orden de su volatilidad son:

- El registro y contenidos de la caché.
- Los contenidos de la memoria.
- El estado de las conexiones de red y las tablas de rutas.
- El estado de los procesos de ejecución.
- El contenido del sistema de archivos y de los discos duros.
- El contenido de otros dispositivos de almacenamiento.



5 METODOLOGÍA FORENSE

RFC 3227

En la normativa RFC 3227 también se especifican diferentes medidas que se deberían llevar a cabo para evitar la destrucción de pruebas, tales como:

- No apagar el equipo hasta que se finalice la recolección de evidencias, ya que un atacante ha podido dejar algún *script* de arranque o apagado que pudiera destruir las evidencias de las acciones que se hayan realizado en el equipo.
- Las aplicaciones deberán ser utilizadas en la medida de lo posible en modo de «solo lectura».
- No se deben ejecutar programas que modifiquen la fecha de accesos a los ficheros.
- Prestar atención a la desconexión del sistema de la Red o de otras conexiones, dado que existen los denominados *deadman switches*, dispositivos que se activan al perder la conexión con el dispositivo y borran el rastro de la infección, eliminando así las evidencias de la intrusión y de las acciones realizadas.

METODOLOGÍA FORENSE

RFC 3227

Otro aspecto importante de la normativa RFC 3227 son las consideraciones de privacidad que presenta. Por ello, se ha de respetar la normativa de protección de datos de la organización a la que pertenezcamos, así como la política del Estado en el que estemos realizando la investigación forense. Para ello, los investigadores se deberán asegurar que ninguna de las evidencias recolectadas sea accesible por personas que no estén relacionadas con la investigación.

Tampoco se deberá invadir la privacidad de un individuo, a menos que haya una justificación sólida de que los ficheros personales a los que se está accediendo poseen evidencias importantes para la investigación, así como asegurar que se tiene claro el procedimiento establecido por la compañía para la recolección de evidencias de un incidente de seguridad.



METODOLOGÍA FORENSE

RFC 3227

Las evidencias que se obtengan deberán cumplir con las siguientes especificaciones o características, ya que deben ser:

- **Admisibles:** esto es, cumplir con la legislación vigente para que las pruebas que se aporten tengan valor en un juicio.
- **Auténticas:** hacer una correlación clara entre la evidencia y el incidente que se está investigando.
- **Completas:** contar los hechos tal y como han sucedido, sin ningún tipo de sesgo.
- **Fidedignas:** no dar lugar a duda sobre su veracidad, análisis, manejo o forma de recolección.
- **Creíbles:** debe ser entendible por todas las partes implicadas en un juicio, por lo que se debe intentar minimizar al máximo posible el lenguaje técnico.

5 METODOLOGÍA FORENSE

EC-COUNCIL (CHFI)

EC-COUNCIL es una organización que ofrece certificaciones, educación y formación en varias áreas de la ciberseguridad, incluido el análisis forense.

Por otro lado, CHFI es una certificación que proporciona EC-COUNCIL y está enfocada a proporcionar los conocimientos prácticos sobre el proceso de detección de ataques de *hacking* y los procedimientos para extraer, de forma correcta, las evidencias digitales que sirvan para identificar el crimen, facilitando así la prevención de sufrir en un futuro ataques similares.



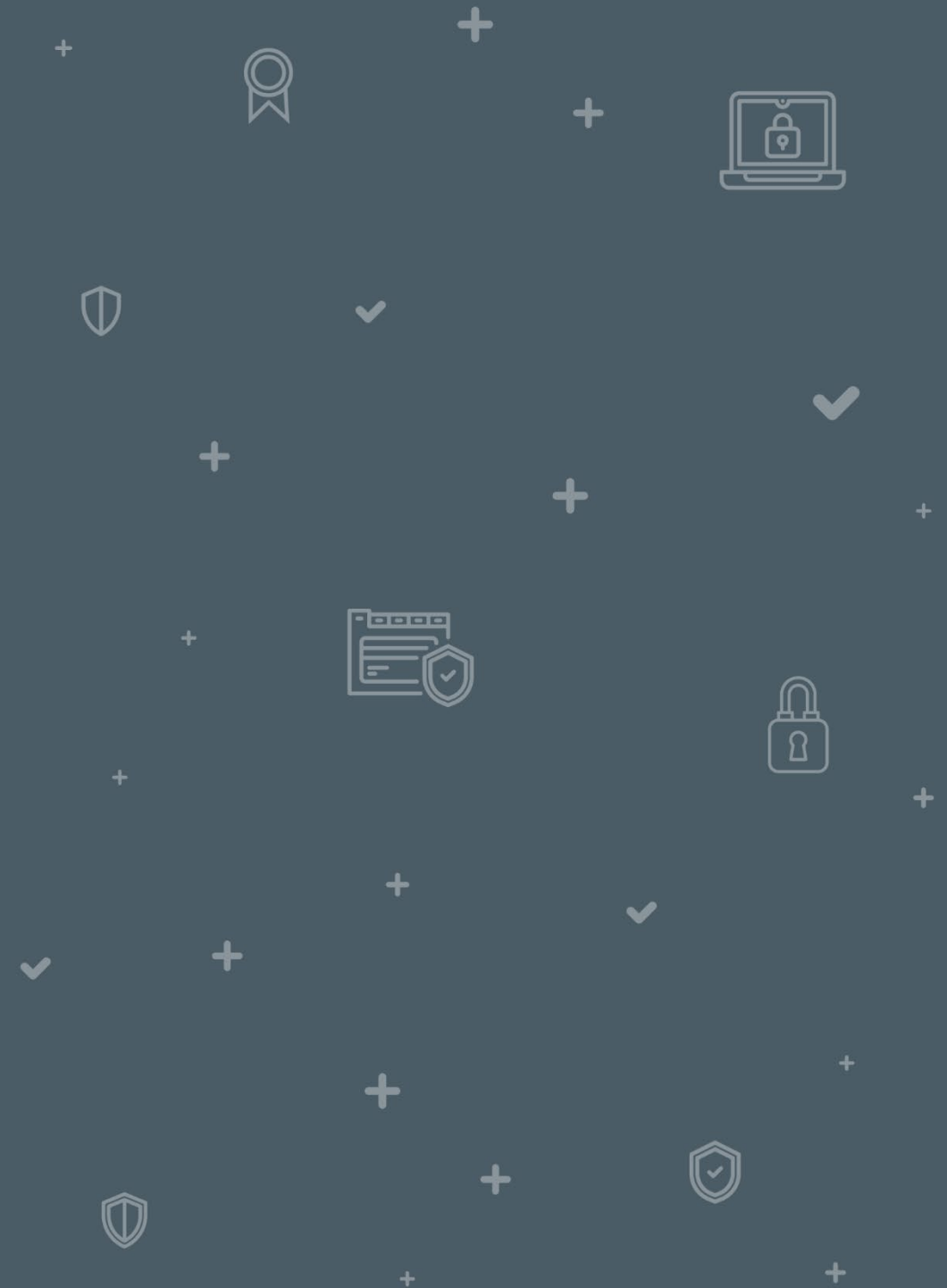
METODOLOGÍA FORENSE

EC-COUNCIL (CHFI)

La metodología de EC-COUNCIL incluye una serie de recomendaciones y consideraciones para el análisis de sistemas en vivo:

- No apagar ni reiniciar un sistema mientras no se hayan recuperado todas las evidencias volátiles.
- Mantener un registro de todas las acciones que se realice en la máquina.
- Hacer capturas de pantalla para poder documentar el estado del sistema.
- Identificar el sistema operativo que se encuentra en ejecución.
- Registrar la fecha y hora del sistema, así como el historial de comandos ejecutados.
- Hacer un volcado de la memoria RAM en un dispositivo externo para su posterior análisis.
- Determinar si el sistema utiliza cifrado de disco o ficheros.
- Recolectar información volátil y almacenarla en un dispositivo externo.
- No ejecutar aplicaciones administrativas que puedan causar cambios en el sistema.
- Determinar los medios que se utilizarán para extraer las evidencias.
- Crear un informe completo que incluya todas las acciones realizadas.

RESUMEN, CONCLUSIONES Y REFERENCIAS



RESUMEN

- La **informática forense** es la aplicación de técnicas de investigación para la recogida de evidencias en diferentes dispositivos informáticos que hayan sufrido algún tipo de incidente de seguridad para, a continuación, ser analizadas en busca de pruebas que puedan aclarar lo que ha ocurrido en el equipo y puedan incluso ser presentadas en un juicio. Esta tarea es llevada a cabo por un **analista forense**, cuyo objetivo principal es hacer una investigación sistemática de las pruebas que este haya adquirido, llevando un informe detallado de lo que se vaya realizando durante todas las etapas de la investigación, así como mantener la integridad de las evidencias. Este proceso también es conocido como **cadena de custodia**.
- Un **análisis forense digital** es un proceso definido y procedimentado mediante el cual se busca determinar los hechos acontecidos durante el suceso de un incidente de seguridad informática. El principio de intercambio de Locard aplicado a la investigación forense digital muestra cada uno de los pasos de un delito, así como tus trazas, es decir, tanto el ciberdelincuente como la víctima del ataque siempre van a dejar pruebas de sus acciones cuando sucede un incidente de seguridad.

RESUMEN

- Los diferentes tipos de *malware* que se pueden encontrar durante un procedimiento de investigación forense son *adwares*, *spyware*, troyano, *rootkit*, *keylogger*, *botnet*, *ransomware* y virus.
- Las fuentes de evidencias de los dispositivos IoT podrán ser categorizadas en tres grupos diferentes, como dispositivos inteligentes y sensores, *software* y *hardware* y recursos externos.
- Un investigador forense deberá ser capaz de diferenciar entre las diversas **arquitecturas de servicios alojados en la nube**: SaaS (*Software as a Service*), PasS (*Platform as a Service*) e IaaS (*Infrastructure as a Service*).
- Las diferentes **fases de la investigación forense digital** conllevan la identificación y el planteamiento del caso, la adquisición y preservación de las evidencias, el análisis de las mismas y la documentación de todo el proceso.
- En cuanto a las **herramientas forenses**, estas pueden ser herramientas *hardware*, como una memoria externa o USB de recuperación, recuperador de contraseñas, protector de escritura de un disco y un controlador de disco forense. Por otro lado, entre las herramientas de *software* podemos *encontrar* Autopsy, FTK Imager y Volatility.

RESUMEN

- En cuanto a los **dispositivos no comunes**, debemos tener en cuenta que en ellos no se lleva a cabo el mismo tipo de análisis forense, sino un **análisis especial**. Estos dispositivos pueden ser RAID, servidores virtualizados, discos cifrados, TomTom, SAN o NAS.
- Las guías de **buenas prácticas** deberán tener en consideración la legislación vigente, ya que son consideradas una buena base para la definición del procedimiento y las políticas propios dentro de cada organización. Estas políticas engloban la recogida y manejo de evidencias, recogida de dispositivos, preparación del equipo y el análisis forense en cuanto a la preparación, el inicio investigación, la examinación y la documentación.

CONCLUSIONES

- Un **incidente de seguridad** se caracteriza por ser una violación de las políticas de seguridad de una organización y tener como resultado algunas consecuencias, como un acceso indebido a los datos, la modificación de los mismos o la destrucción de estos. Esta incidencia deberá ser resuelta por el equipo de seguridad de la organización con la mayor brevedad posible. Una vez contenido o aislado un incidente de seguridad, se procederá a realizar una investigación forense para poder averiguar las causas de este.
- Un **análisis forense** es el análisis sistemático llevado a cabo por un equipo informático con el objetivo de obtener evidencias que demuestren lo acontecido. Los pasos a seguir durante una investigación forense digital son la recuperación de evidencias, el transporte de las mismas, su posterior análisis y la preparación de un informe que describa lo ocurrido.

CONCLUSIONES

- El primer paso a realizar en una **investigación forense digital** es identificar los motivos por los que se realiza la misma, los responsables y dispositivos afectados e iniciar la cadena de custodia. A continuación, se procederá a realizar la adquisición de evidencias teniendo en cuenta la diferencia entre evidencias volátiles, estas son, evidencias que se pueden perder en caso de que se produzca un cambio en equipo afectado, y evidencias no volátiles. Además, se realizará un clonado de la información almacenada en los dispositivos para su posterior análisis. Tras la fase de adquisición, se procederá a realizar el análisis de evidencias sobre las copias de las mismas para mantener la integridad de las originales.
- La **línea temporal** de los hechos acontecidos durante una investigación forense digital apoyará en el fortalecimiento de los argumentos que se esgrimirán durante la realización del informe final.

CONCLUSIONES

- La **cadena de custodia** es un protocolo para el manejo de las evidencias que se obtengan durante una investigación forense, que indicará quién ha accedido a las evidencias y todas aquellas acciones que se hayan realizado durante la investigación, de manera que asegurará la integridad de las evidencias durante toda la investigación. Por otro lado, las evidencias deberán estar firmadas utilizando la función *hash* para demostrar que no ha sucedido ningún cambio durante la investigación.
- Existen diferentes **tipos de análisis forense**, como el análisis de bases de datos, de correos electrónicos, de *malware*, de la memoria, de dispositivos móviles o de redes.
- Los **artefactos** hacen referencia a los diferentes ficheros, rutas de acceso y configuración que pueden constituir una evidencia relevante para la investigación forense digital.
- Asimismo, existen diferentes **técnicas** que utilizan los analistas forenses durante una investigación forense digital, como la recuperación de los archivos borrados u ocultos, el análisis forense estocástico, la técnica denominada *Forensic Feature Extraction* (FFE), el análisis cruzado de discos o el análisis en vivo.

CONCLUSIONES

- Existe una gran cantidad de herramientas que ofrecen todo tipo de funcionalidades a la hora de realizar una investigación forense digital, complementando la labor y el conocimiento del analista forense. Estas herramientas pueden ser **herramientas *hardware* o *software***. Por un lado, las herramientas *hardware* se centran en mantener las evidencias intactas mientras que las herramientas *software* tiene como fin la recogida y análisis de las evidencias.
- Un **análisis forense** tiene como objetivo encontrar las evidencias que determinen lo acontecido durante un incidente de seguridad, mientras que **un análisis de *malware*** identifica los archivos maliciosos y, en base a ello, genera soluciones.
- Un **análisis de dispositivos IoT** se caracteriza por el aumento del alcance en el que un analista forense debe investigar, dado que estos dispositivos pueden estar interconectados entre sí y las evidencias de un incidente de seguridad pueden estar repartidas entre distintos dispositivos o repositorios alojados en la nube.

CONCLUSIONES

- Un **análisis forense en la nube** presenta dificultades a la hora de recoger evidencias, ya que, muchas veces, los clientes dependerán de un tercero para acceder a la infraestructura de los servidores en la nube y obtener los datos puede no ser una tarea fácil.
- Los dispositivos no comunes sobre los que se deberán tener ciertas consideraciones a la hora de realizar una investigación forense digital pueden tener varios discos duros interconectados o cifrados. En este caso, se deberán tener en cuenta todas las variaciones que pueden tener un dispositivo antes de hacer un análisis forense.
- Dado que un análisis forense se utiliza para la investigación judicial, existen numerosas **normativas** que se encargan de gestionar las responsabilidades de los analistas forenses, por ejemplo, la UNE 197001:2019, la UNE 71506:2013 de las tecnologías de la información (TI), la RFC 3227 (*Guidelines for Evidence Collection and Archiving*) y EC-Council (CHFI).

REFERENCIAS

- Servidor virtual: qué es y principales características.
<https://www.beservices.es/que-un-servidor-virtual-caracteristicas-n-5392-es>
- Introducción al análisis forense en entornos *cloud*.
https://www.redseguridad.com/especialidades-tic/cloud-y-virtualizacion/introduccion-al-analisis-forense-en-entornos-cloud_20201028.html
- Diferencias entre prueba, evidencia, indicio, rastros y huellas.
<https://directorioforense.com/index.php/2018/07/16/diferencias-entre-prueba-evidencia-indicio-rastros-y-huellas/>
- *Best Practices for Computer Forensics*.
https://www.oas.org/juridico/spanish/cyb_best_pract.pdf

REFERENCIAS COMPLEMENTARIAS

-
- [1] Ataque DDoS a una operadora de telecomunicaciones.
<https://www.xataka.com/otros/asi-fue-ciberataque-ddos-que-bloqueo-red-andorra-saboteo-a-algunos-streamers-espanoles-conocidos-pleno-torneo>

 - [2] Ciberataque de *ransomware* a una empresa tecnológica a la que se le ha exigido 50 millones.
<https://www.xataka.com/seguridad/exigen-a-acer-50-millones-dolares-ciberataque-mayor-rescate-ransomware-fecha>

 - [3] Casos de análisis forense más peculiares.
<https://www.xataka.com/seguridad/soy-perito-informatico-estos-algunos-casos-surrealistas-que-he-trabajado-1>

 - [4] Código deontológico de los peritos judiciales.
<https://apjude.com/wp-content/uploads/2020/03/codigo-deontologico.pdf>

 - [5] Cómo funciona el algoritmo Ssdeep / sdhash.
[https://dfir.science/2017/07/How-To-Fuzzy-Hashing-with-SSDEEP-\(similarity-matching\).html](https://dfir.science/2017/07/How-To-Fuzzy-Hashing-with-SSDEEP-(similarity-matching).html)

REFERENCIAS COMPLEMENTARIAS

-
- [6] Mejores herramientas gratuitas de informática forense.
<https://www.redeszone.net/tutoriales/seguridad/mejores-herramientas-gratuitas-informatica-forense/>
- [7] Artefactos de Windows y ruta de artefactos (pág. 80).
<https://people.ccaba.upc.edu/careglio/wp-content/uploads/2020/06/SI-Tema7.pdf>
- [8] UNE 197001:2019.
<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0062378>
- [9] UNE 71506:2013.
<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0051414>
- [10] ISO/IEC 27037:2016.
<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0057481>
- [11] SimBad afectó a 206 aplicaciones provocando así una campaña masiva de *adware* móvil.
<https://research.checkpoint.com/2019/simbad-a-rogue-adware-campaign-on-google-play/>

REFERENCIAS COMPLEMENTARIAS

-
- [12] *Spyware* Torisma.
<https://blogs.masterhacks.net/noticias/hacking-y-ciberdelitos/hackers-norcoreanos-utilizaron-el-spyware-torisma-en-ataques-basados-en-ofertas-de-trabajo/>
- [13] Bizarro es un nuevo troyano que ha atacado a más de 70 bancos en todo el mundo.
<https://computerhoy.com/noticias/tecnologia/troyano-bizarro-sigue-provocando-victimas-gana-confianza-867425>
- [14] INCIBE dispone a través de la OSI un servicio *antibonet*.
<https://www.incibe.es/ciudadania/herramientas/servicio-antibotnet>
- [15] La *botnet* Meris, a través de 250.000 dispositivos, ha conseguido batir el récord del mayor ataque DDoS dos veces.
<https://www.genbeta.com/actualidad/asi-meris-nueva-botnet-que-ha-conseguido-batir-dos-veces-record-ataque-ddos-grande-historia>

REFERENCIAS COMPLEMENTARIAS

-
- [16] Estos son los 5 grupos de *ransomware* más activos de los últimos años.
<https://www.kaspersky.es/blog/top5-ransomware-groups/25126/>
- [17] Mydoom.
<https://www.recoverylabs.com/ayuda-y-soporte/data-recovery-white-papers/informes-de-investigacion/virus-mydoom/>
- [18] Sasser.
<https://es.ccm.net/contents/750-el-gusano-sasser>
- [19] Stuxnet.
https://www.bbc.com/mundo/noticias/2015/10/151007_iwonder_finde_tecnologia_virus_stuxnet
- [20] Triton.
<https://www.technologyreview.es/s/11009/asi-se-propaga-triton-el-malware-que-amenaza-la-industria-mundial>

REFERENCIAS COMPLEMENTARIAS

-
- [21] El origen de Stuxnet.
<https://www.kaspersky.es/blog/el-origen-de-stuxnet/4887/>
- [22] UNE 197001:2019.
<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0062378>
- [23] UNE 71506:2013.
<http://www.aenor.es/aenor/normas/normas/fichanorma.asp?tipo=N&codigo=N0051414&PDF=Si#.UjlcYj9xpNo>
- [24] RFC 3227.
<https://www.ietf.org/rfc/rfc3227.txt>
- [25] EC-Council (CHFI).
<https://www.eccouncil.org/train-certify/computer-hacking-forensic-investigator-chfi/>

¡GRACIAS!

